
NIC26



Tatu Seppälä

Security Architect

Microsoft Microsoft MVP Security

Context&

Mastering Purview Data Security Solution Design: Lessons from Years of Deployments

Agenda

- 🌱 Tenant-level preparations
- 🏷️ Sensitivity labels & encryption
- 💭 Data Loss Prevention
- 🏗️ Running the implementation project

We **focus** on the **technical stuff** that will trip you up

NIC26

“Purview data security deployments are
20% tech / 80% comms!”

Yes, and you need to get that 20% **exactly** **right.**

NIC26

Secure by default with Microsoft Purview



Foundational

Start with recommended labels

Activities

- Start with default labels and protection at file and site level
- Turn on data security pre-requisites and adv. analytics
- Train users on managing exceptions
- Turn on DLP for labeled content

Outcomes

- M365 new/updated content protected

Managed

Address files with highest sensitivity

Activities

- Manually configure priority sites default library labeling
- Autolabeling for credentials and contextual conditions
- Turn on DLP for content that is not labeled
- Turn on Adaptive Protection and data leak behavioral rules

Outcomes

- M365 priority content protected

Optimized

Expand to your entire M365 data estate

Activities

- Auto-label sensitive files on clients (low thresholds)
- Simulate auto-labeling sensitive files at rest
- Reduce false positives with advanced classifiers
- Automate and improve M365 protection to historical and in use data

Outcomes

- M365 historical content protected

Strategic

Operate, expand, and retroactive actions

Activities

- Operational review of user labeling behaviors
- Iterate with new labeling scenarios
- Set up accountability chain and lifecycle management
- Extend protection to Azure SQL and non-M365 storage

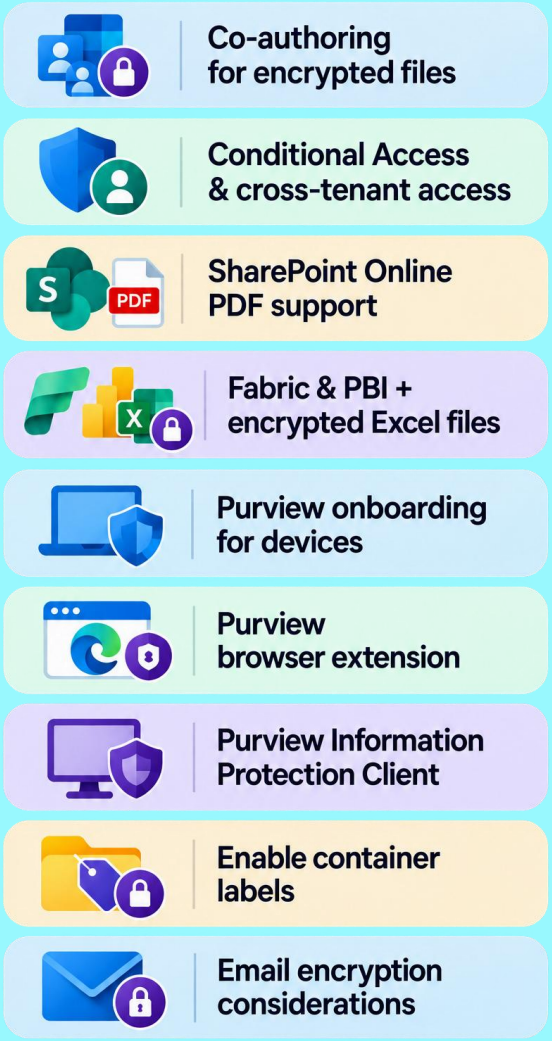
Outcomes

- Protection beyond M365

NIC26

Source: Secure by default with Microsoft Purview | Microsoft Learn

Tenant-level preparations





“Help! I used a sensitivity label to protect my document and now Mark from sales **can’t work on it at the same time** with me anymore!

Also, **auto-save doesn’t work** now.. 😔 ”

NIC26

Co-authoring for files with sensitivity labels

This setting allows users in your organization to co-author in Office desktop documents that are encrypted by using sensitivity labels. To support this new capability, all users must have the latest Microsoft 365 Apps for enterprise and label metadata must be upgraded for all labeled documents that aren't encrypted. Learn more about this one-time setting

Prerequisites

- Sensitivity labels must be enabled for files in OneDrive and SharePoint. If this isn't already done, we'll enable this for you when you turn on co-authoring.
- Minimum versions of apps to support the new labeling metadata.
- Latest Microsoft 365 Apps for enterprise.
- Any labeling apps or solutions you've deployed use the minimum supported version of the MIP SDK.
- Any scripts or tools you're using that read from or write to the labeling metadata for documents are updated to use the new metadata format and location.

Learn more about these prerequisites

What to expect after turning this on

- When existing labeled and unencrypted documents are opened and saved, the sensitivity label information that's currently stored as a custom property is copied and saved to a new

Turn on co-authoring for files with sensitivity labels

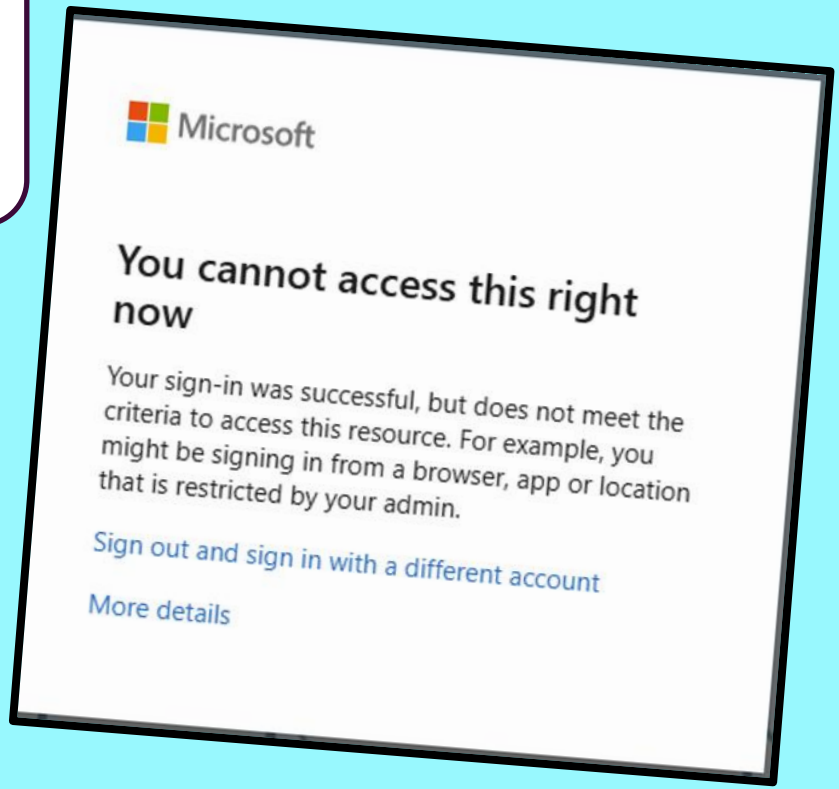
When this was turned on, we also enabled sensitivity labels for files in OneDrive and SharePoint if it wasn't already enabled. Learn more

⚠ To turn this switch off, you'll need to use PowerShell. Before turning off, make sure you understand the

Conditional Access & cross-tenant access

Mary from our external marketing partner is telling me **she can't open the document I protected with a label.** I'm sure I gave her permissions to it!





Conditional Access & cross-tenant access

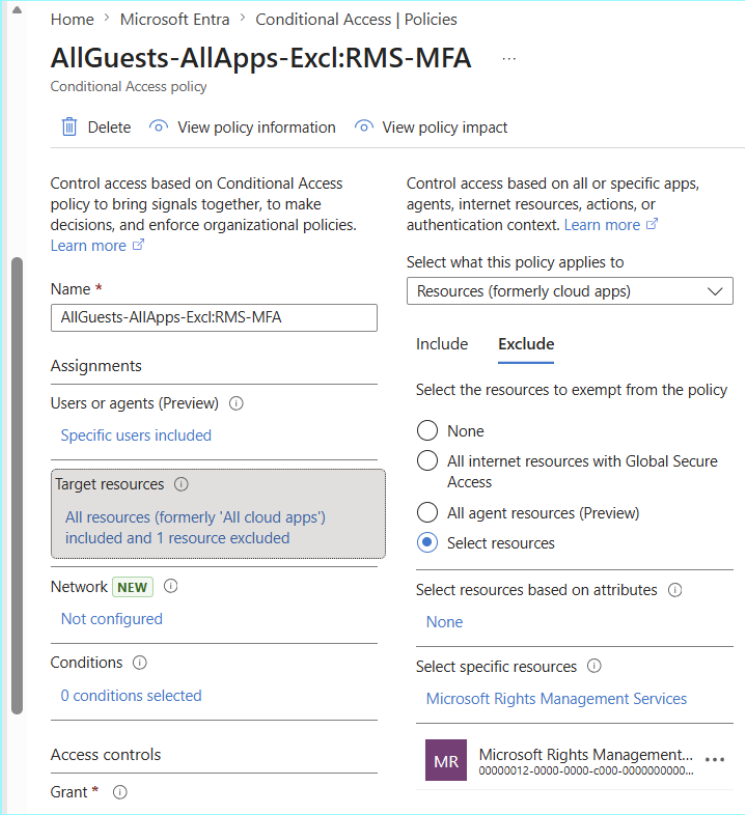
Read more



Mary from our external marketing partner is telling me she can't open the document I protected with a label. I'm sure I gave her permissions to it!

Option 1: Exclude MRMS cloud app from CA policies targeting guests + all apps w/ MFA

Microsoft Rights Management Services
00000012-0000-0000-c000-000000000000



Conditional Access & cross-tenant access

Option 2: Trust external MFA claims for specific partner organizations

Inbound access settings - Contoso ···

B2B collaboration | B2B direct connect | **Trust settings** | Cross-tenant sync

Configure whether your Conditional Access policies will accept claims from other Microsoft En
external Microsoft Entra tenants except those with organization-specific settings.

You'll first need to configure Conditional Access for guest users on all cloud apps if you want t
Entra hybrid joined.
Learn more

- ○ Default settings
- ◉ Customize settings

- ☑ Trust multifactor authentication from Microsoft Entra tenants
- ☐ Trust compliant devices
- ☐ Trust Microsoft Entra hybrid joined devices



SharePoint Online PDF support (+ video & OneNote labeling support)

```
Connect-SPOService –URL https://contoso-admin.sharepoint.com

// Enable labeling, DLP support, eDiscovery & more for PDF
Set-SPOTenant -EnableSensitivityLabelforPDF $true

// Enable labeling for OneNote
Set-SPOTenant -EnableSensitivityLabelforOneNote $true

// Enable labeling for videos uploaded to SharePoint Online
Set-SPOTenant -EnableSensitivityLabelforVideoFiles $true
```



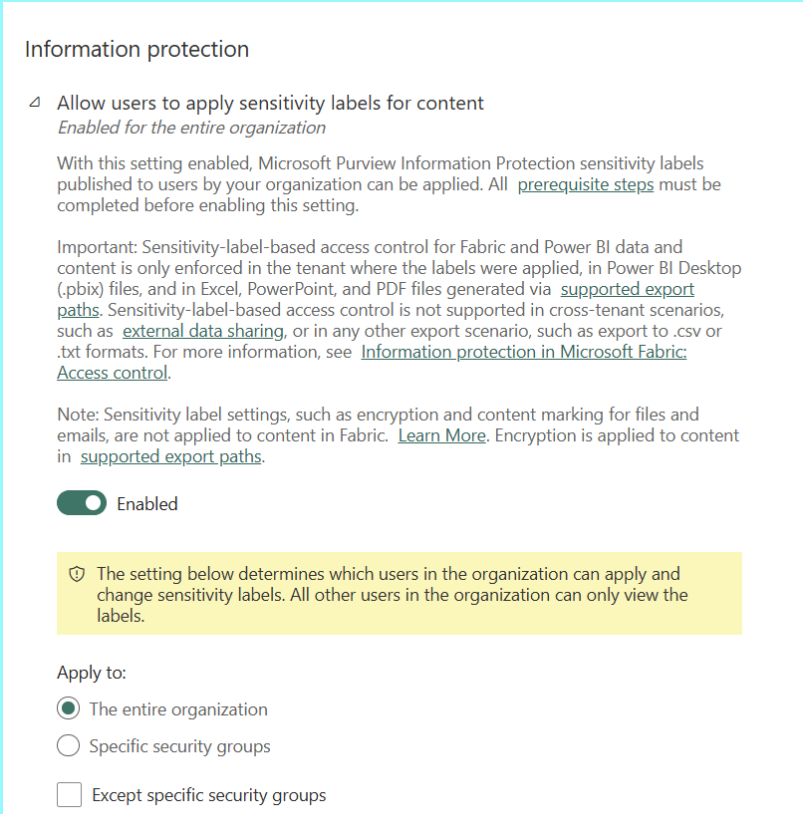
Fabric & Power BI compatibility w/ encrypted Excel files



Jane from business analytics called. Their Power BI report is broken and won't refresh. Yeah, the one based on the **Excel file.**

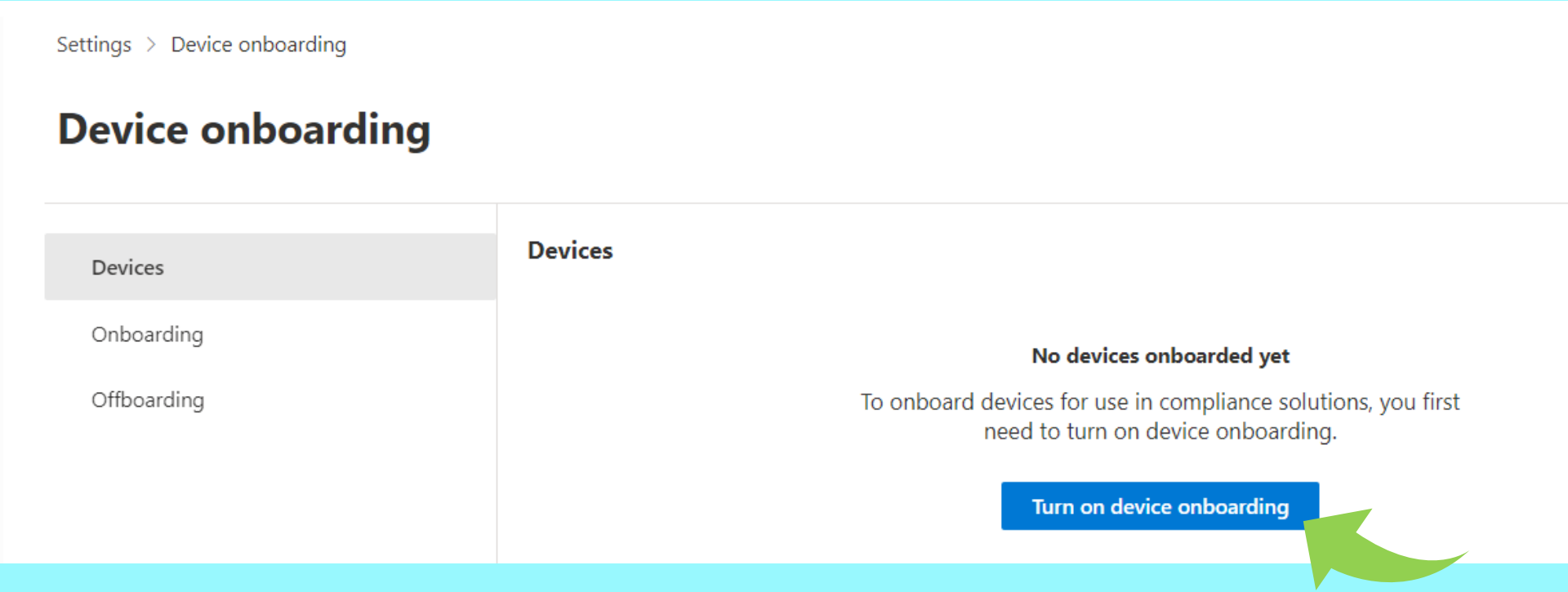
❗ Sensitivity label encrypted XLSX files will only work as a data source for users that can apply labels to content in Fabric & Power BI.

NIC26



Onboard Defender for Endpoint devices to Purview

Easy to miss! Required for both the audit trail & Endpoint DLP controls.





Ok, we **onboarded** our Defender for Endpoint devices to Purview.

Now we got all these new events in the **Unified Audit Log** – nice!

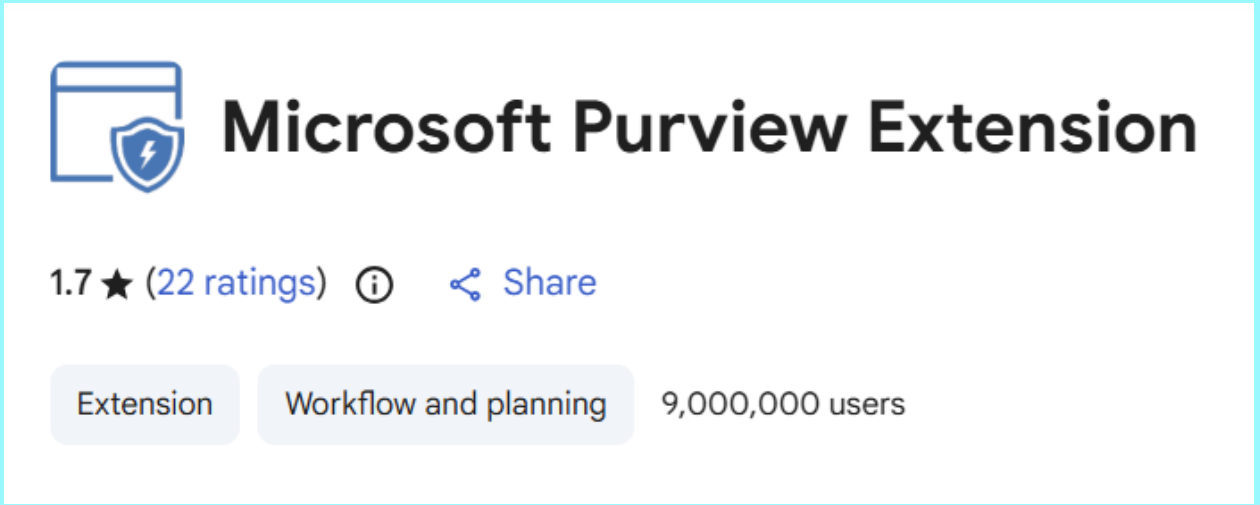
NIC26

File read 89372
Label applied 7009
File created 32119
File renamed 24827
File created on removable media 12533
File created on network share 10730
File modified 9531
File Archived 2354
File copied to network share 2069
File printed 1576
Label removed 47
Archive created 543
File copied to removable media 190
Label changed 5
File copied to cloud 134
File discovered 3
File copied to remote desktop session 38
Protection removed 0

Deploy the Purview browser extension



We're using **Chrome** as our primary enterprise browser, not Edge. We *are* still covered.. right?



NIC26

1.7 ★ (22 ratings) Share



Fabián Rosell ★☆☆☆☆ 9 Feb 2026

"This item's installation is required by your organization"

1 person found this review to be helpful

J

Jonathan Goren IL ★☆☆☆☆ 8 Jan 2026

time and energy wasting bossware

1 person found this review to be helpful

M

Michael Dooley ★★★★★ 16 Jun 2025

This extension changed my life, this is the single greatest piece of technology that any proclaimed 'free-thinking society' could ever hope to create. My outlook on religion, spirituality, and the forces that govern creation have undergone a vast and transformative journey ever since installing this application.

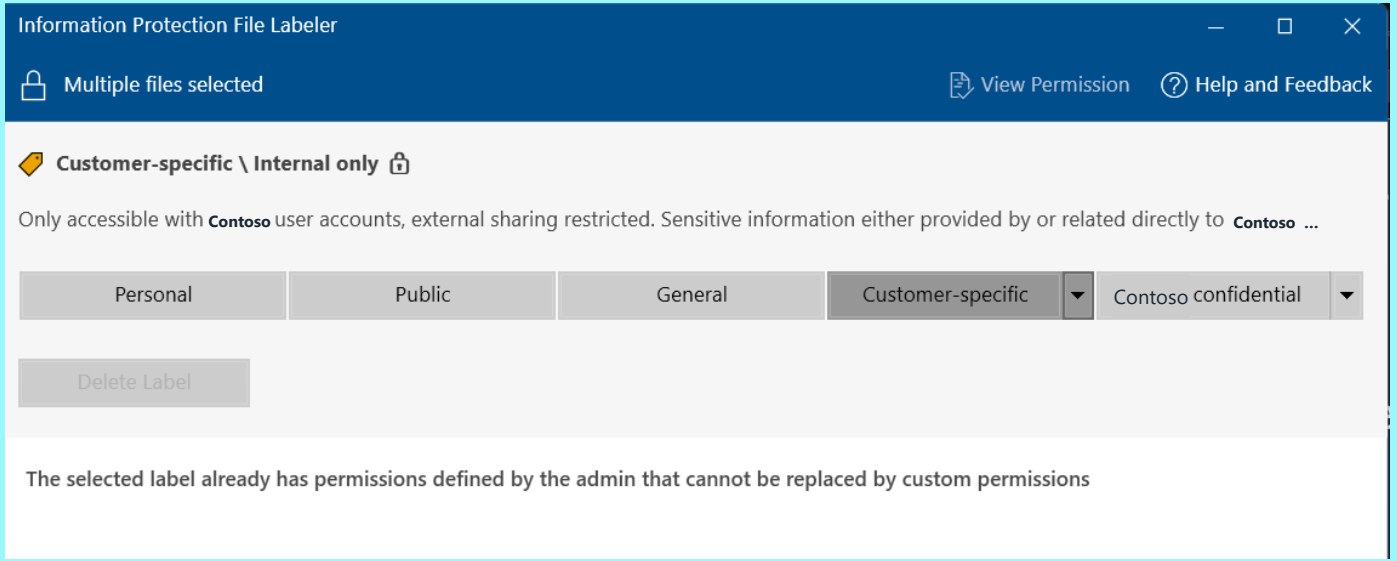
13 out of 21 found this helpful

13 out of 21 found this helpful

Distribute Purview Information Protection Client via Intune/GPO



Legal needs to label and protect 1000+ sensitive files on a local network share and they're NOT going to do it one file at a time. **Can we help them?**



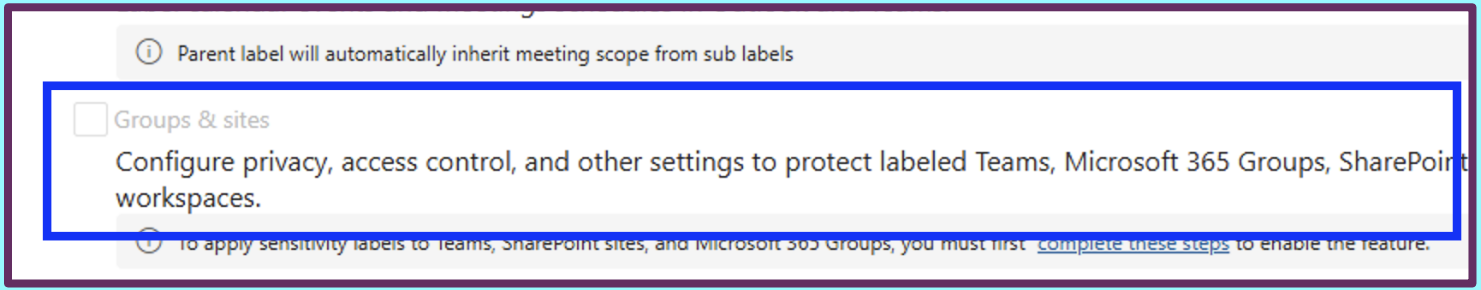
NIC26

Enable container labels

We now want to scope our sensitivity labels to groups and sites, but the option is greyed out.

What's the problem? 🤔





N

Read more

Enable container labels (1/2)



```
// Install modules
Install-PSResource Microsoft.Graph.Authentication -Scope CurrentUser
Install-PSResource Microsoft.Graph.Beta.Identity.DirectoryManagement -Scope CurrentUser
Import-Module Microsoft.Graph.Authentication, Microsoft.Graph.Identity.DirectoryManagement
// Connect to Graph
Connect-MgGraph -Scopes "Directory.ReadWrite.All“
// Define new setting
$TemplateId = (Get-MgBetaDirectorySettingTemplate | where { $_.DisplayName -eq "Group.Unified" }).Id
$params = @{
  templateId = "$TemplateId"
  values = @(
    @{
      name = "EnableMIPLabels"
      value = "True"
    }
  )
}
```

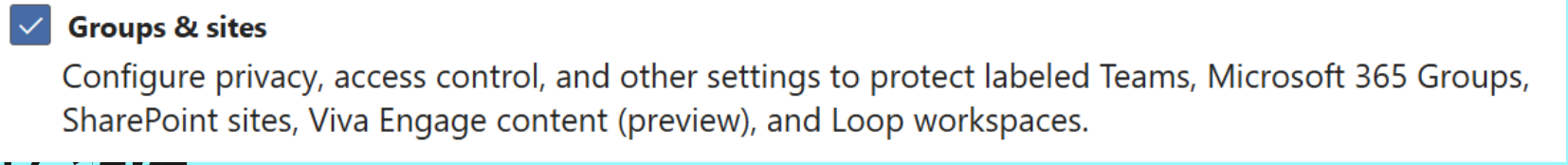
N

Read more

Enable container labels (2/2)

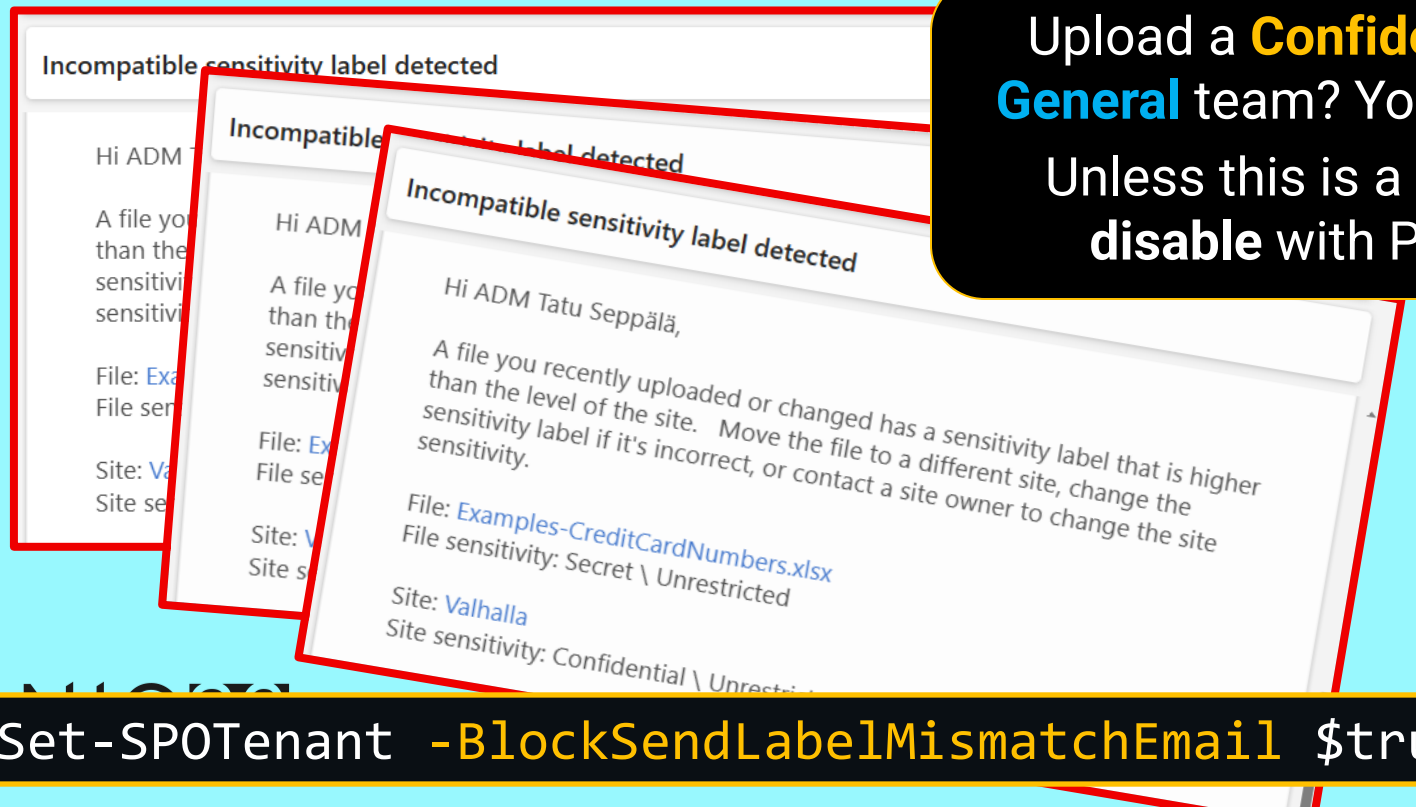
```
// IF SETTING DOESN'T EXIST: Create the new directory setting
New-MgBetaDirectorySetting -BodyParameter $params
// IF SETTING EXISTS: Update the directory setting
$setting = Get-MgBetaDirectorySetting | Where-Object {$_.DisplayName -eq "Group.Unified"}
($setting.Values | Where-Object { $_.Name -eq "EnableMIPLabels" }).Value = "True"
Update-MgBetaDirectorySetting -DirectorySettingId $setting.Id -Values $setting.Values
// Sync the changes
Connect-IPPSSession
Execute-AzureAdLabelSync
```

⏳ ..then wait about 1h



NTC26

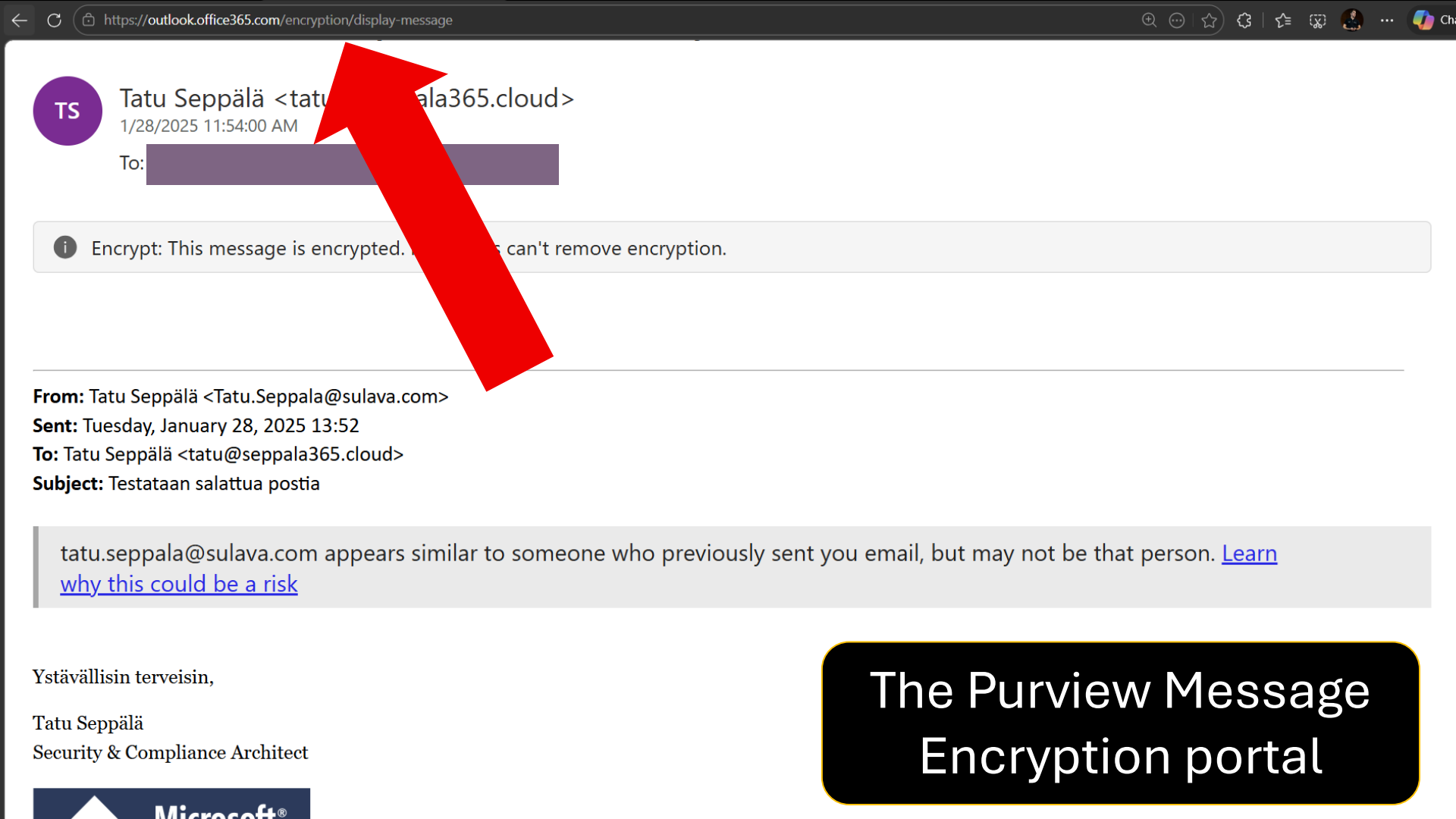
Label mismatch email spam



Upload a **Confidential** file to a **General** team? You get an email.

Unless this is a requirement, **disable** with PowerShell.

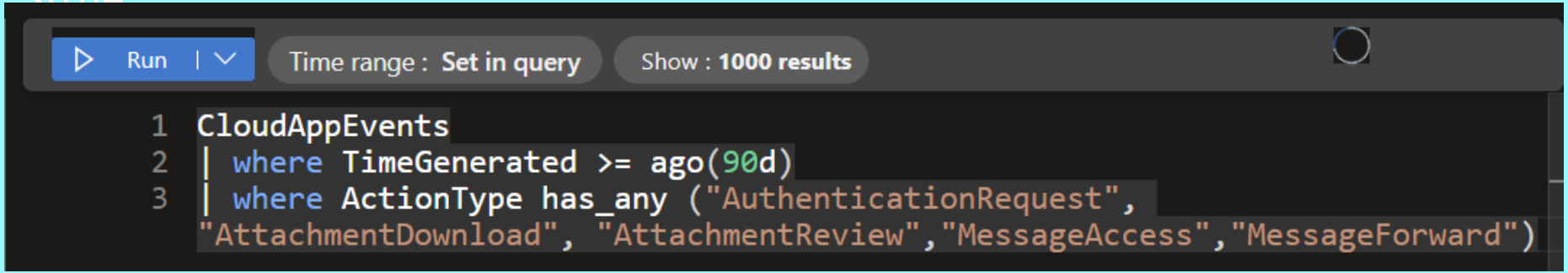
```
Set-SPOTenant -BlockSendLabelMismatchEmail $true
```


https://outlook.office365.com/encryption/display-message
TS
Tatu Seppälä <tatu
ala365.cloud>
1/28/2025 11:54:00 AM
To:
Encrypt: This message is encrypted.
can't remove encryption.
From: Tatu Seppälä <Tatu.Seppala@sulava.com>
Sent: Tuesday, January 28, 2025 13:52
To: Tatu Seppälä <tatu@seppala365.cloud>
Subject: Testataan salattua postia
tatu.seppala@sulava.com appears similar to someone who previously sent you email, but may not be that person. Learn why this could be a risk
Ystävällisin terveisin,
Tatu Seppälä
Security & Compliance Architect
Microsoft
The Purview Message Encryption portal

Email encryption considerations

Message Encryption portal audit logs **not** on by default! → **Enable**

```
Set-IrmConfiguration -EnablePortalTrackingLogs
$true
```

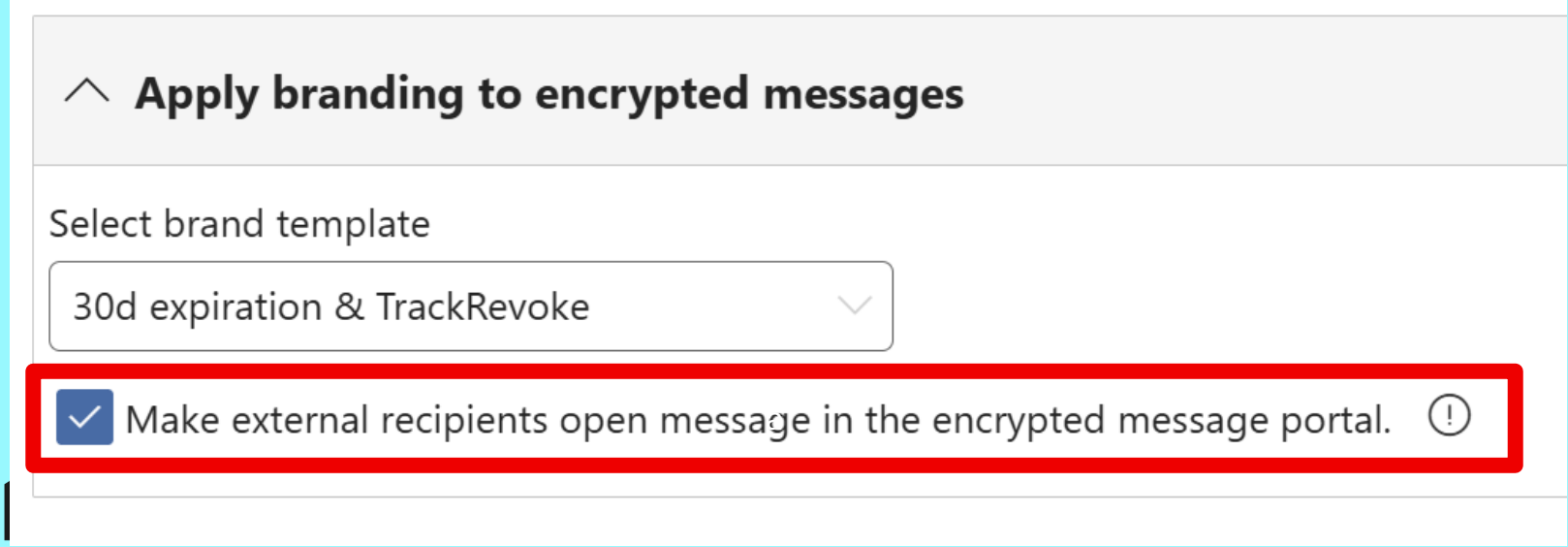


NIC26

Email encryption considerations

If consistent audit logging required

→ Use EXO DLP to force viewing encrypted email in portal.



Sensitivity Labels



NIC26

I don’t understand what the labels do.



There are too many options for me..



Why do I need to label everything??

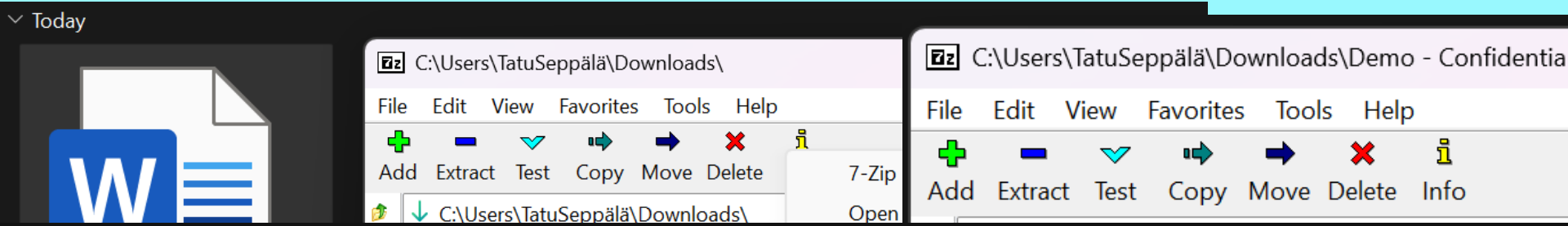




I don’t want to use sensitivity labels because they break everything!

NIC26

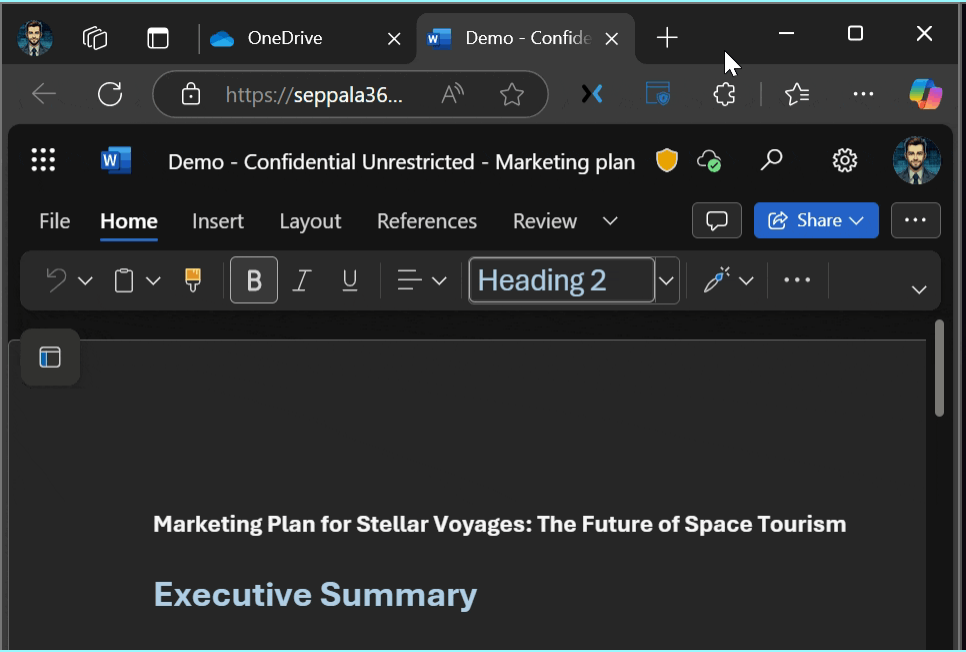
Files only have one sensitivity label at a time? **Myth!**

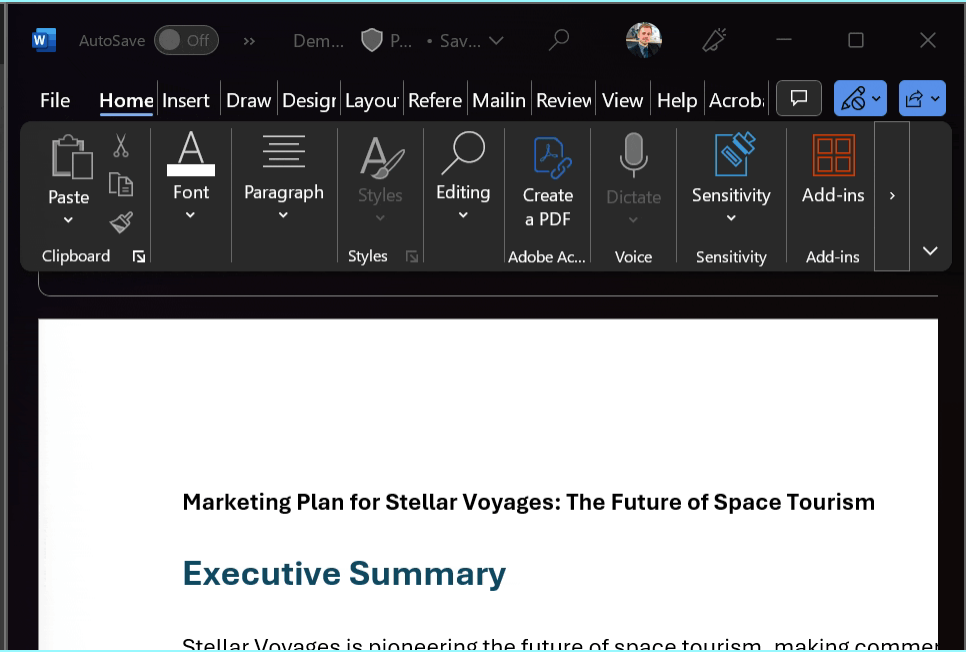


This XML file does not appear to have any style information associated with it. The document tree is shown below.

```
▼<clbl:labelList
 xmlns:clbl="http://schemas.microsoft.com/office/2020/mipLabelMetadata">
   <clbl:label id="{5948967a-be92-4652-bda9-521b79f86c10}" enabled="1"
   method="Privileged" siteId="{1bd4438f-2095-465c-9caa-763ca6b7bafb}" removed="0"/>
   <clbl:label id="{8705de8d-079b-4759-949e-8937c8bcb0b3}" enabled="1"
   method="Privileged" siteId="{5b73a072-2f1f-46ad-92ca-a9b3993e45aa}" contentBits="0"
   removed="0"/>
 </clbl:labelList>
```

Files only have one sensitivity label at a time? **Myth!**





NIC26

Emails only have one sensitivity label at a time? **Myth!**

```
MSIP_Label_957fede7-68ad-4516-b302-935b6f81af8c_Enabled=True
MSIP_Label_957fede7-68ad-4516-b302-935b6f81af8c_SiteId=5b73a072-2f1f-46ad-92ca-a9b3993e45aa
MSIP_Label_957fede7-68ad-4516-b302-935b6f81af8c_SetDate=2025-02-13T13:32:59.899Z
MSIP_Label_957fede7-68ad-4516-b302-935b6f81af8c_Name=General
MSIP_Label_957fede7-68ad-4516-b302-935b6f81af8c_ContentBits=0
MSIP_Label_957fede7-68ad-4516-b302-935b6f81af8c_Method=Standard

MSIP_Label_defa4170-0d19-0005-0002-bc88714345d2_Enabled=True
MSIP_Label_defa4170-0d19-0005-0002-bc88714345d2_SiteId=1bd4438f-2095-465c-9caa-763ca6b7bafb
MSIP_Label_defa4170-0d19-0005-0002-bc88714345d2_SetDate=2025-02-13T13:33:41.421Z
MSIP_Label_defa4170-0d19-0005-0002-bc88714345d2_Name=General
MSIP_Label_defa4170-0d19-0005-0002-bc88714345d2_ContentBits=0
MSIP_Label_defa4170-0d19-0005-0002-bc88714345d2_Method=Standard
```

SiteId captures the M365 tenant ID >>

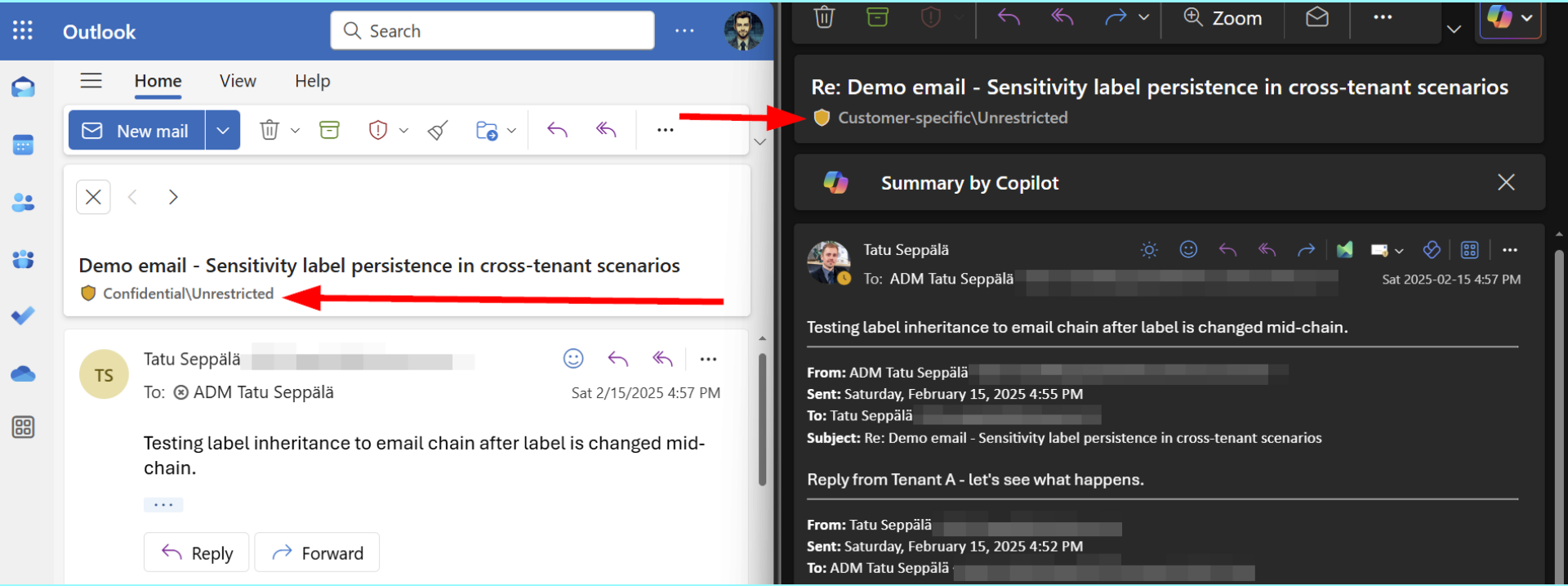
Name captures the sensitivity label name >>



❗ **Note:** Some providers like Gmail drop label metadata from headers when the Gmail user replies to an email labeled in your tenant

NIC26

Emails only have one sensitivity label at a time? **Myth!**



NIC26

..remember the **KISS** principle

Keep It Simple, Stupid!



NIC26

Personal

Public

Internal

Confidential

Highly confidential

Secret



NIC26

Public

General

Confidential

Secret

...

...



NIC26

General

Confidential

...

...



NIC26

Parent label /
Label group
→ indicates **risk level**

Sublabel
→ indicates **audience**



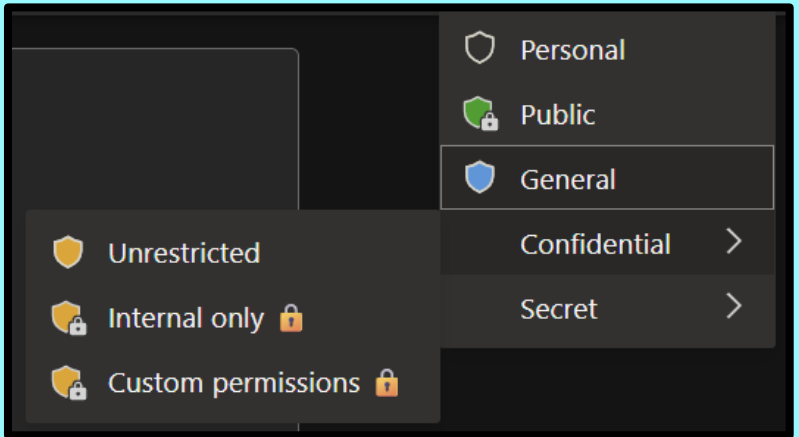
Don’t mix terminology indicating **technical restrictions** with terminology indicating **sensitivity**

NIC26

Parent label /
Label group
→ indicates **risk level**

Sublabel
→ indicates **audience**





NIC26

Planning for visual markings



The header text from the Confidential sensitivity label overlays our existing document template elements – it's annoying!

- Markings don't care about what is on your template
- They **will** overlap with whatever's already there!
- **Check and prepare all DOCX & PPTX templates**

Seppala365 Confidential / Internal use only

Pre-existing footer text

Planning for visual markings



The header text from the Confidential sensitivity label overlays our existing document template elements – it's annoying!

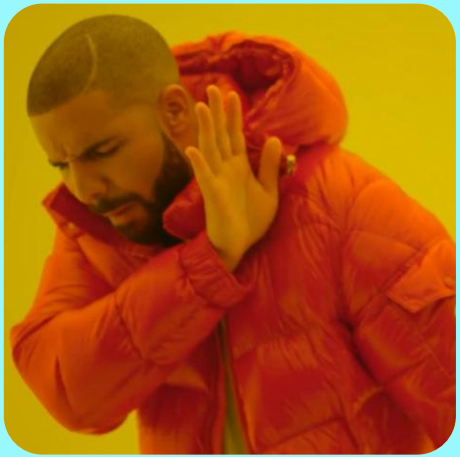
Control markings by app!

```
${If.App.Word}This Word document is sensitive ${If.End}
```

Tweak margins with PowerShell (min. 15px)

```
Set-Label –Identity "LabelName"
–ApplyContentMarkingFooterMargin 15
–ApplyContentMarkingHeaderMargin 30
```

NIC26



Confidential information that must be handled according to company policy.



Sensitive internal business data crucial to achieving organizational goals.

💡 Examples: Contracts and payment information, sensitive personal information, sales and forecast data, future or existing business plans, detailed descriptions of internal technical solutions.

📄 Files & email: Encrypted, access only by Seppala365 user accounts.

📦 Teams teams and SharePoint sites: Access only with Seppala 365 user accounts, external sharing restricted.

Unrestricted

Internal only

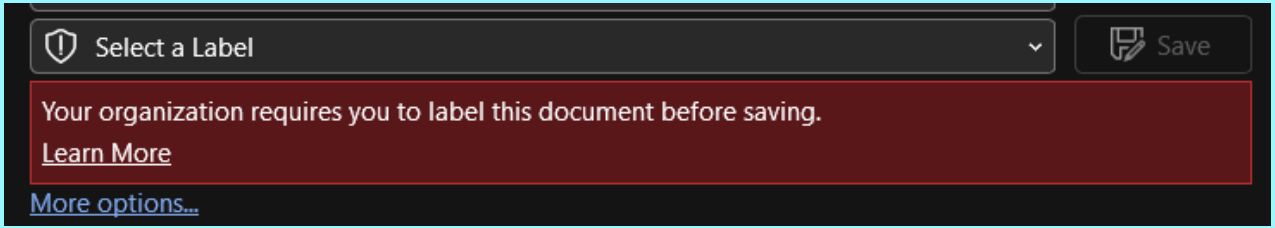
Custom permissions

Mandatory labelling – you need it!

Why do I need to label every single document??
It is tanking my productivity.. 😓

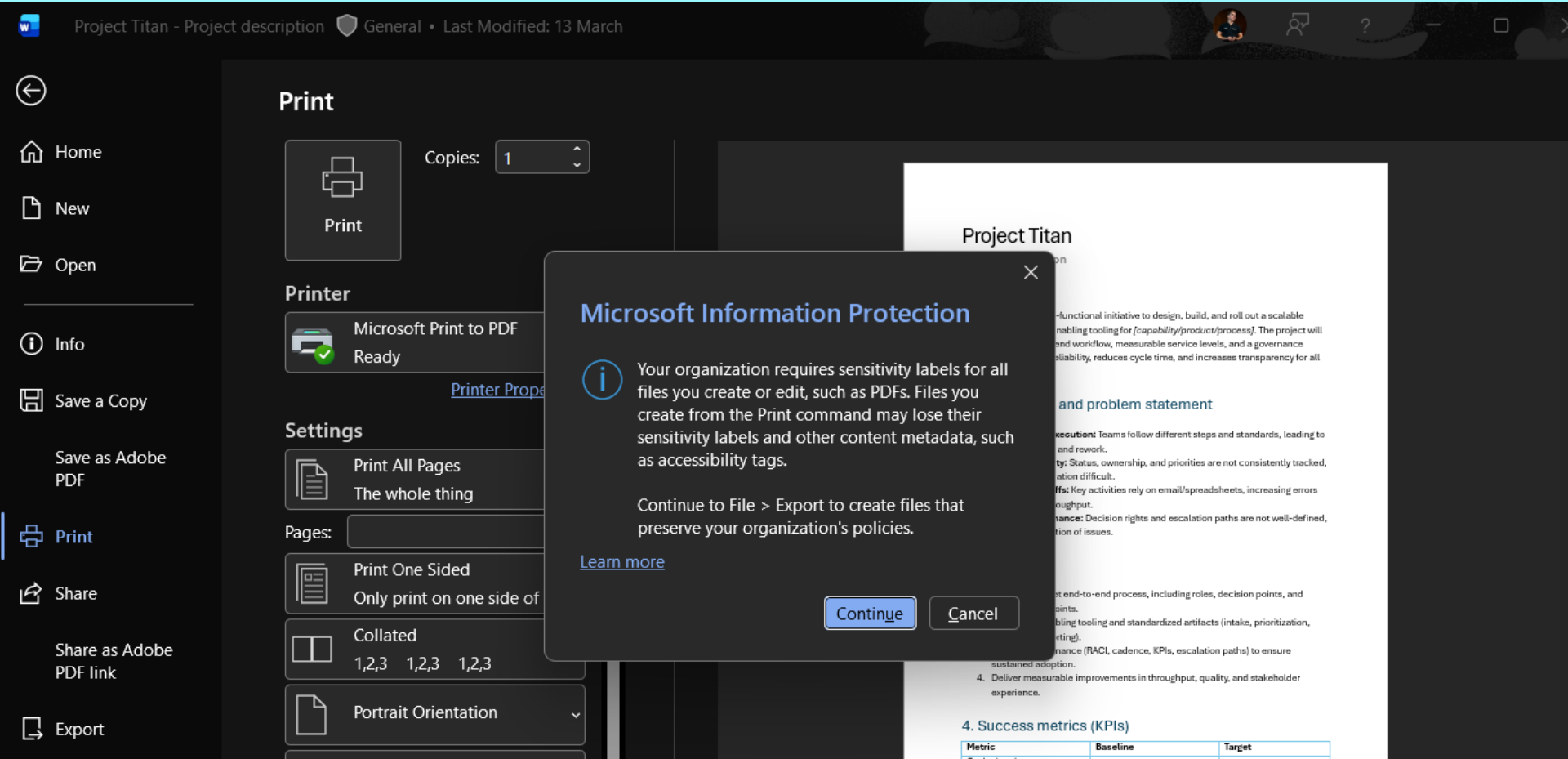


- We're **hardwired** to avoid cognitively taxing actions if we don't see the benefit or understand why
- Many will initially not see the point of sensitivity labels!
- Mandatory labelling helps bridge the gap before a **habit** has time to form over weeks / months



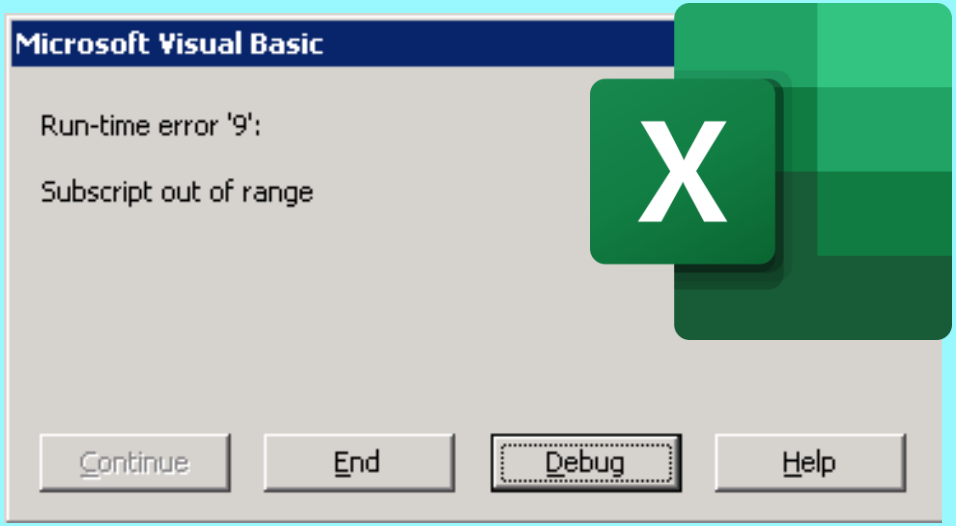
NIC26

Mandatory labelling blocks Microsoft Print to PDF



Mandatory labelling *breaks* unlabeled Excel files w/ VB scripts

- Never underestimate how many business processes are based on some XLSX file w/ VB script from 20 years ago
- Identify & pre-label!
- Look at **FileAccessed** events in the UAL



NIC26

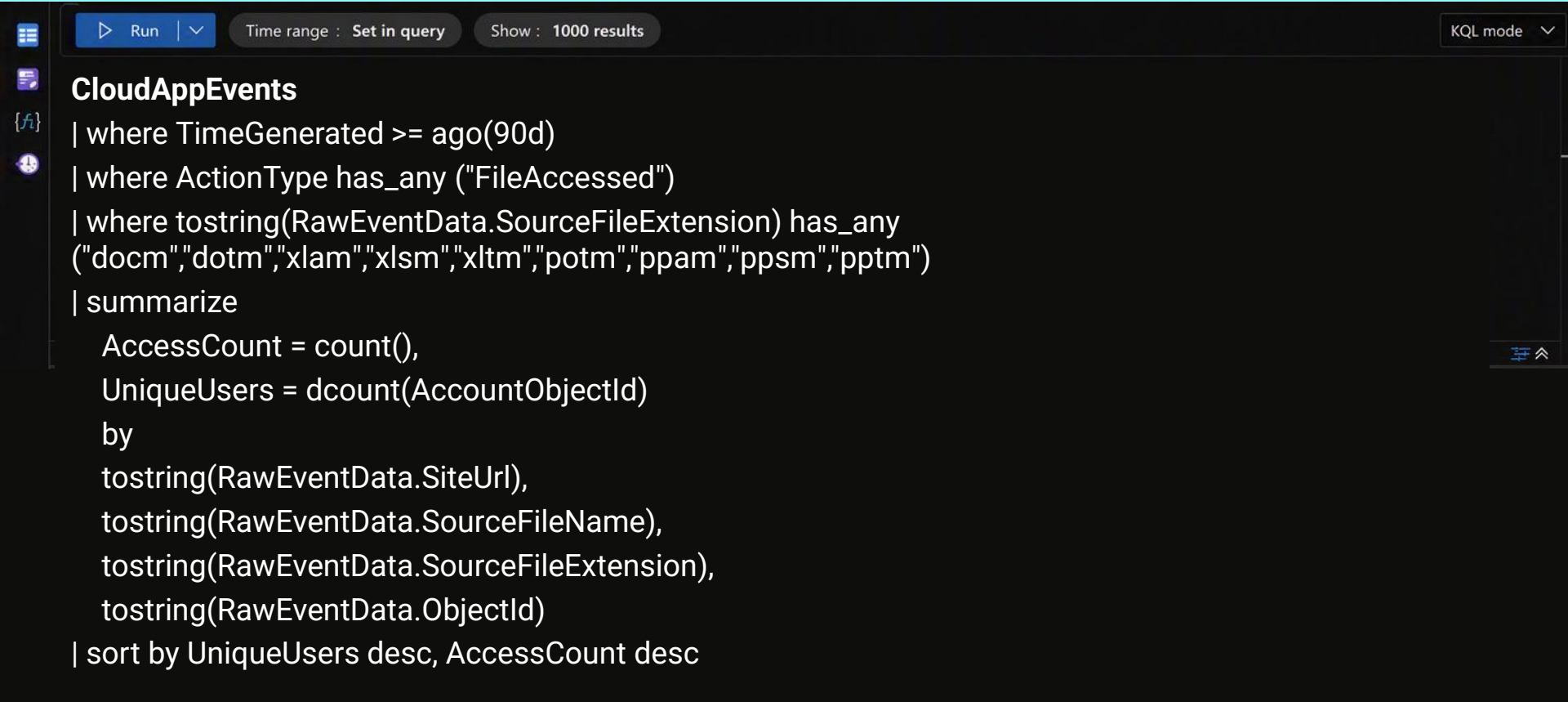
Run | Time range : **Set in query** | Show : **1000 results** | KQL mode

```
CloudAppEvents
| where TimeGenerated >= ago(90d)
| where ActionType has_any ("FileAccessed")
| where tostring(RawEventData.SourceFileExtension) has_any ("docm","dotm","xlam","xlsm","xltm","potm","ppam","ppsm","pptm")
| summarize
    AccessCount = count(),
    UniqueUsers = dcount(AccountObjectId)
    by
    tostring(RawEventData.SiteUrl),
    tostring(RawEventData.SourceFileName),
    tostring(RawEventData.SourceFileExtension),
    tostring(RawEventData.ObjectId)
| sort by UniqueUsers desc, AccessCount desc
```

Results | Chart

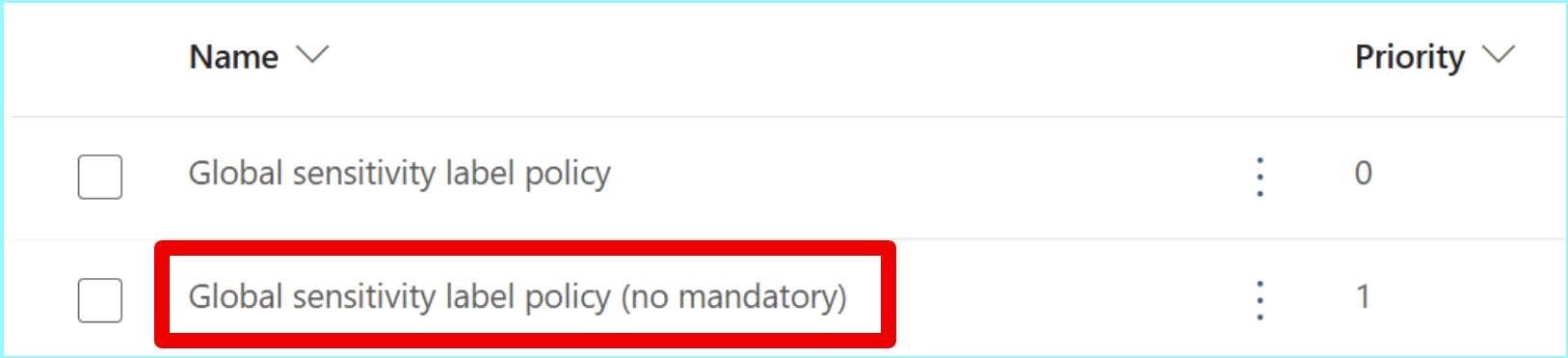
RawEventData_SiteUrl	RawEventData_SourceFileName	RawEventData_SourceFileExtension	RawEventData_ObjectId	UniqueUsers	AccessCount
https://contoso.sharepoint.com/sites/Finance	Finance_MonthEnd_Close.xlsm	xlsm	https://contoso.sharepoint.com/sites/Finance/Shared Documents/Close Process/Finance_MonthEnd_Close.xlsm	87	412
https://contoso.sharepoint.com/sites/Sales	Sales_Commission_Calculator.xlsm	xlsm	https://contoso.sharepoint.com/sites/Sales/Shared Documents/Compensation/ Sales_Commission_Calculator.xlsm	76	298
https://fabrikam.sharepoint.com/sites/PMO	Resource_Planning_Tool.xlsm	xlsm	https://fabrikam.sharepoint.com/sites/PMO/Shared Documents/Tools/Resource_Planning_Tool.xlsm	64	245
https://contoso.sharepoint.com/sites/Finance	Vendor_Payment_Reconciliation.xlsm	xlsm	https://contoso.sharepoint.com/sites/Finance/Shared Documents/Operations/ Vendor_Payment_Reconciliation.xlsm	58	210
https://contoso.sharepoint.com/sites/Finance	Project_Portfolio_Dashboard.xlsm	xlsm	https://Portoso.sharepoint.com/sites/Finance/Shared Documents/Reporting/ Project_Portfolio_Dashboard.xlsm	52	188
https://northwind.sharepoint.com/sites/ERisk	Risk_Register_Automation.xlsm	xlsm	https://northwind.sharepoint.com/sites/ERisk/Shared Documents/Tools/Risk_Register_Automation.xlsm	48	176
https://northwind.sharepoint.com/sites/Finance	Corporate_Finance_Tools.xlam	xlam	https://northwind.sharepoint.com/sites/Finance/Shared Documents/ AddIns/Corporate_Finance_Tools.xlam	46	163
https://contoso.sharepoint.com/sites/PMO	PMO_Reporting_Addin.xlam	xlam	https://contoso.sharepoint.com/sites/PMO/Shared Documents/AddIns/PMO_Reporting_Addin.xlam	42	151
https://fabrikam.sharepoint.com/sites/Finance	Monthly_Budget_Template.xltm	xltm	https://fabrikam.sharepoint.com/sites/Finance/Shared Documents/Templates/ Monthly_Budget_Template.xltm	41	149
https://contoso.sharepoint.com/sites/FPandA	Forecasting_Workbook_Template.xltm	xltm	https://contoso.sharepoint.com/sites/FPandA/Shared Documents/Templates/ Forecasting_Workbook_Template.xltm	40	141
https://contoso.sharepoint.com/sites/Legal	Contract_Review_Assistant.docm	docm	https://contoso.sharepoint.com/sites/Legal/Shared Documents/Automation/ Contract_Review_Assistant.docm	38	138
https://fabrikam.sharepoint.com/sites/Legal	Statement_of_Work_Generator.docm	docm	https://fabrikam.sharepoint.com/sites/Legal/Shared Documents/Automation/ Statement_of_Work_Generator.docm	37	129
https://northwind.sharepoint.com/sites/Consulting	Consulting_Deliverable_Template.dotm	dotm	https://northwind.sharepoint.com/sites/Consulting/Shared Documents/Templates/ Consulting_Deliverable_Template.dotm	35	121
https://contoso.sharepoint.com/sites/SalesEnablement	Proposal_Template.dotm	dotm	https://contoso.sharepoint.com/sites/SalesEnablement/Shared Documents/Templates/Proposal_Template.dotm	33	116
https://contoso.sharepoint.com/sites/ExecutiveOffice	Quarterly_Business_Review.pptm	pptm	https://contoso.sharepoint.com/sites/ExecutiveOffice/Shared Documents/QBR/ (Quarterly_Business_Review.pptm	31	112

🔎 Take-home hunting query: Macro-enabled file access




```
CloudAppEvents
| where TimeGenerated >= ago(90d)
| where ActionType has_any ("FileAccessed")
| where tostring(RawEventData.SourceFileExtension) has_any
("docm","dotm","xlam","xlsm","xltm","potm","ppam","ppsm","pptm")
| summarize
    AccessCount = count(),
    UniqueUsers = dcount(AccountObjectId)
    by
    tostring(RawEventData.SiteUrl),
    tostring(RawEventData.SourceFileName),
    tostring(RawEventData.SourceFileExtension),
    tostring(RawEventData.ObjectId)
| sort by UniqueUsers desc, AccessCount desc
```

Prepare to **exclude** users from mandatory labelling



- Set up additional **Label Publishing Policy** tied to **Microsoft 365 Group**
- **Turn off mandatory labelling** for this special policy
- Make the policy **higher priority** than the regular policy
- If systemic issues found → add users to group & investigate

NIC26

Default labels - a poisoned chalice!

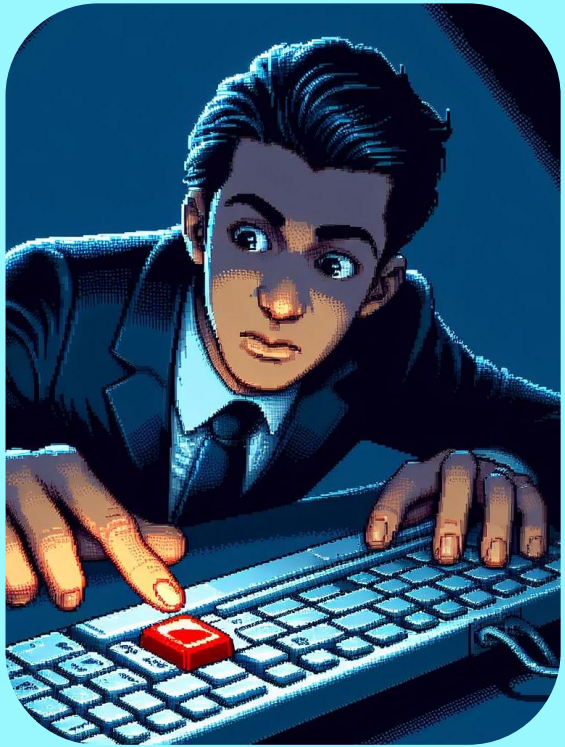
Apply a default label to documents

The label you choose will automatically be applied to Word, Excel, and PowerPoint documents when they're created or modified. Users can always select a different label to better match the sensitivity of their document. Learn which Office app versions support this setting

Default label

General



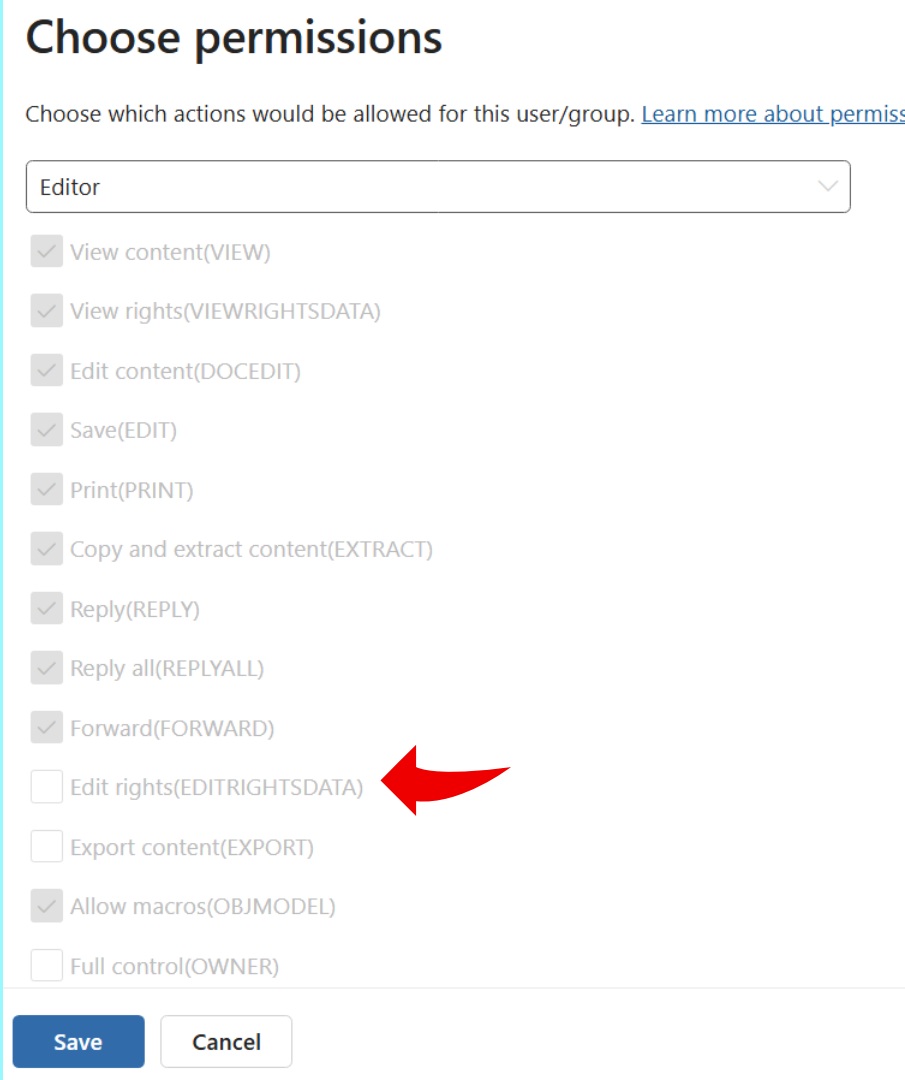


NTC26

File encryption:
Careful with permissions

- Microsoft offers **Editor** permissions by default
- It doesn't have the **EDITRIGHTSDATA** permission
- ❗ **Implication:** Nobody except the document labeler can change the label anymore
- **This breaks sensitivity label lifecycle**

NIC26



File encryption: Careful with permissions

- Smart admins use **Owner** for org-wide “internal” encryption instead
- Reserve more limited permissions for special use / limited audience labels

Deep dives on sensitivity label encryption in my blog →

NIC26



Confidential \ All Employees	Confidential data that requires protection, which allows all employees full permissions. Data owners can track and revoke content.	This label is selected as the default label for documents and sites. **Scope**: Files and other data assets (File, Email, Meetings, Sites) **Encryption**: All users and groups in the org: Co-Author (note: encryption of labels can be implemented later) **Content marking**: Footer: Classified as Confidential **Auto-labeling**: No **Site privacy**: Private or Public **Data Loss Prevention**: Block anyone with the link, Block external

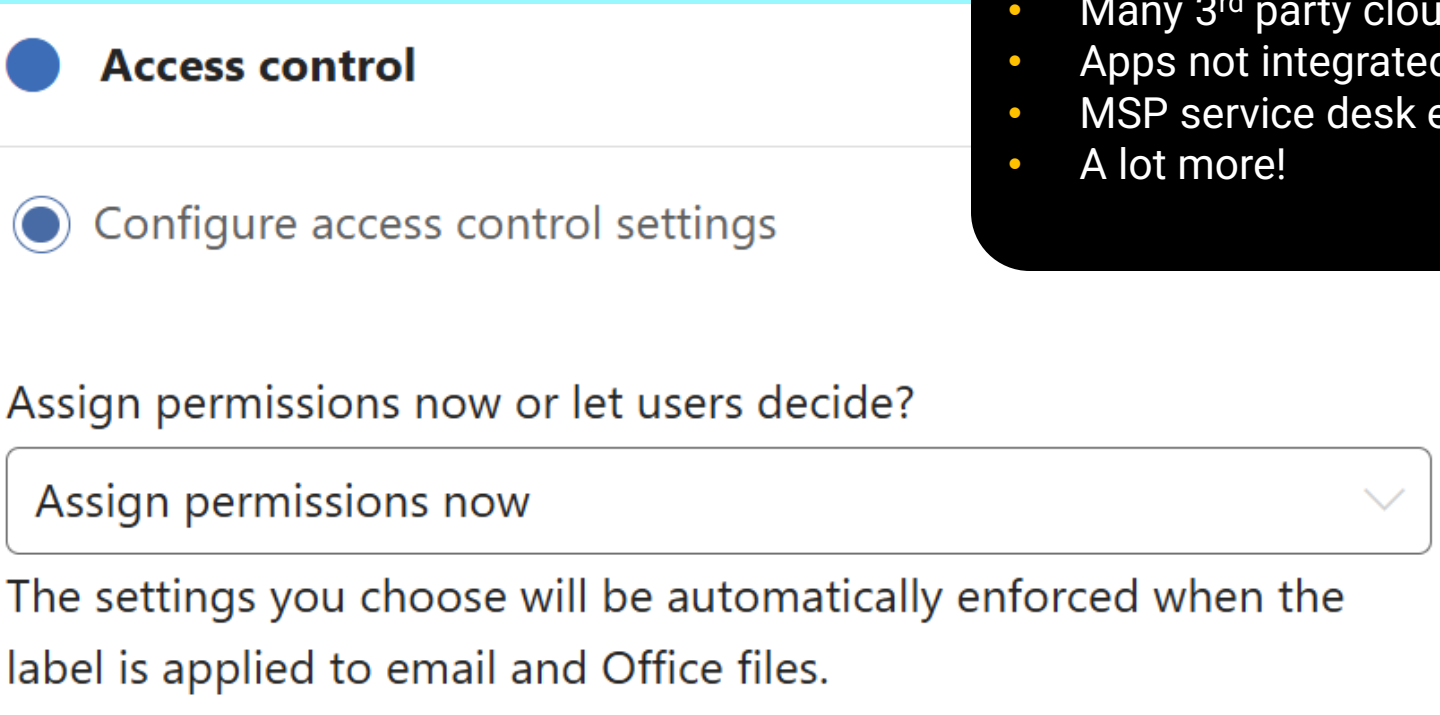


[Step 1: Start with default labeling - Secure by default with Microsoft Purview | Microsoft Learn]

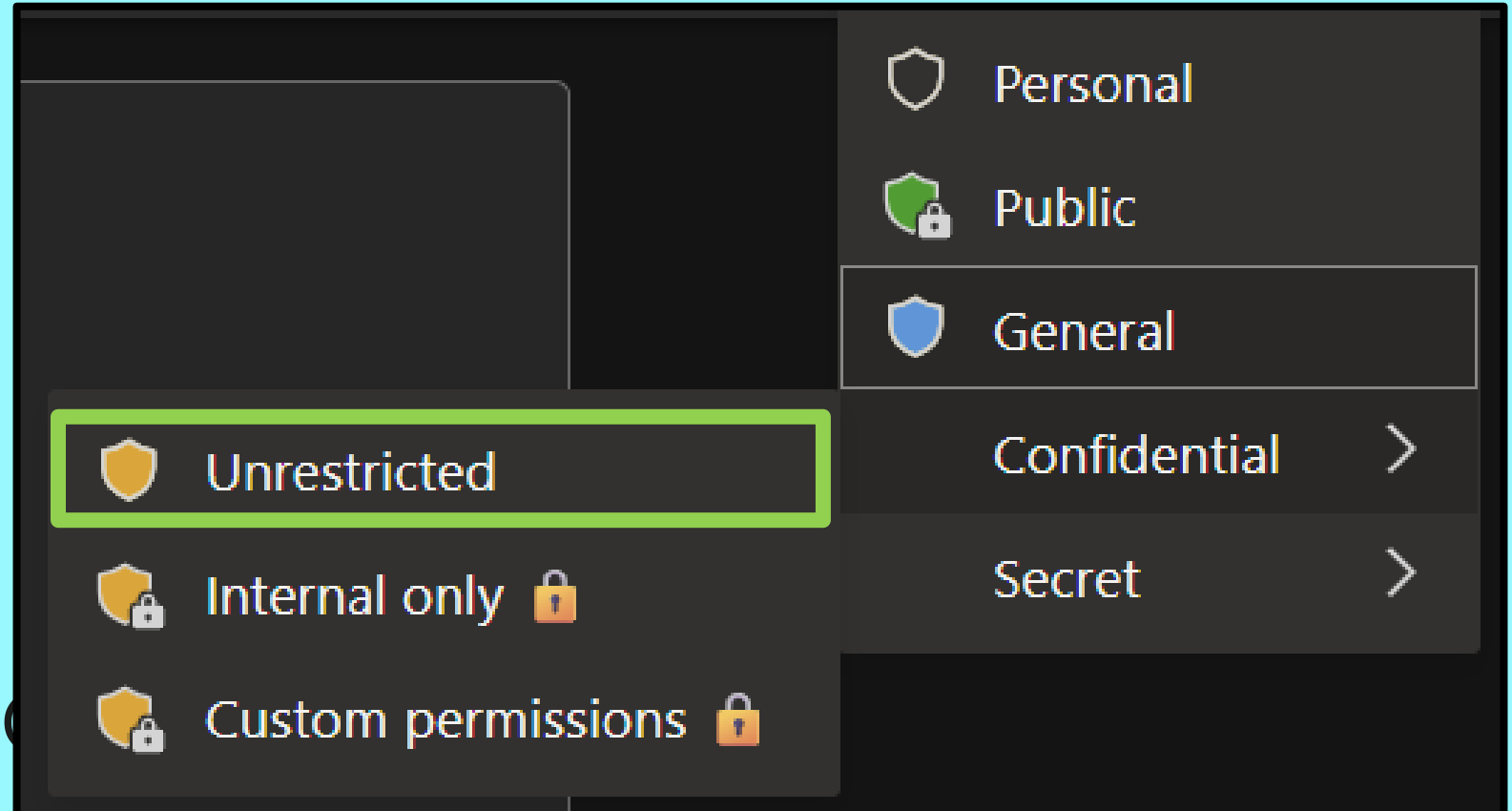
Provide unencrypted sublabels

Label encryption breaks..

- Many 3rd party cloud services
- Apps not integrated with MIP SDK
- MSP service desk email processing
- A lot more!

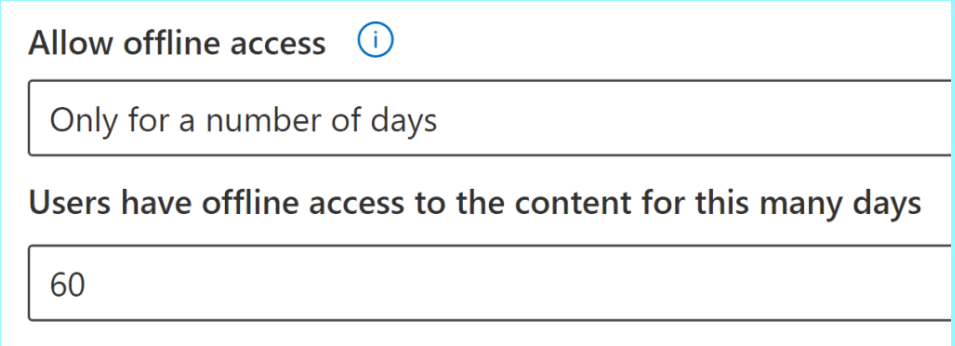


Provide unencrypted sublabels



File encryption – use licenses

- Open encrypted doc on a machine → get per-user, per-document, per-machine limited-time ability to access contents
- User rights defined in label permissions are only rechecked after license expires → **requires internet connection**



Use license validity is invisibly capped at 30d by default.

You can change this w/ PowerShell (AIPService module)

File decryption

My colleague Kate protected a file with custom permissions before she left and now we can't change the permissions!



```
Unlock-SPOSensitivityLabelEncryptedFile
-FileUrl "https://path-to/file.docx"
-JustificationText "Reason for decryption"
```

Reference

+ **Super User** role enabled & assigned

```
Set-FileLabel "C:\Path\To\file.docx" –RemoveProtection -RemoveLabel -
JustificationMessage 'Reason for decryption'
```

Reference

Email encryption hiccups



I sent a document in a **Do Not Forward** encrypted email to my boss - and now they can't print it!

Do Not Forward: Recipients can't forward, print, or copy content.

Send | From: Tatu.Seppala@sulava.com

To: ADM Tatu Seppälä <adm-tatu@seppala365dev.onmicrosoft.com>

Cc:

DNF encrypted email demo

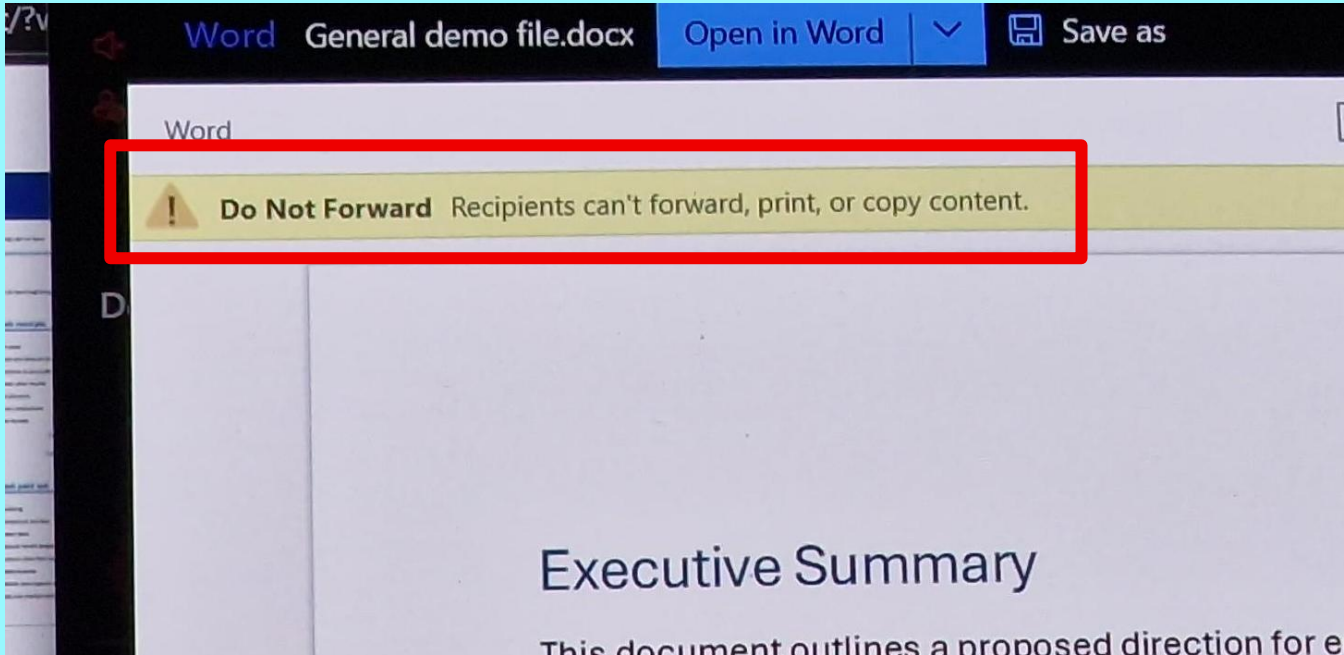
Very important demo file.xlsx
9 KB

NIC26

Email encryption hiccups



I sent an Excel sheet in a **Do Not Forward** encrypted email to my boss - and now they can't print it!



NIC26

Email encryption hiccups



I sent an Excel sheet in a **Do Not Forward** encrypted email to my boss - and now they can't print it!

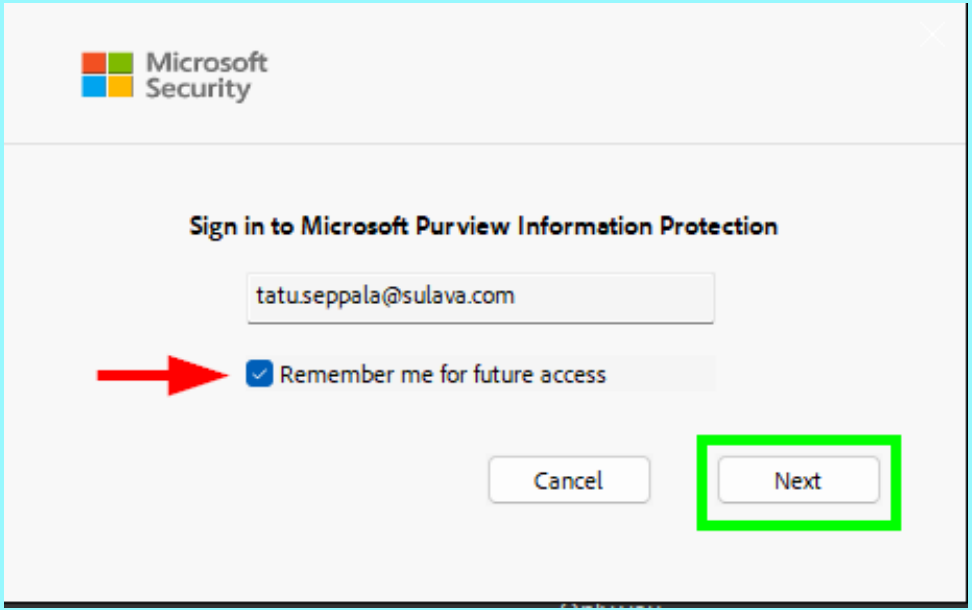
- Message Encryption inherits to unencrypted supported attachments
  - You can disable inheritance for encrypt-only
  - You cannot disable inheritance for Do Not Forward
- Careful when two email encryption solutions are in play – DLP can help auto-decrypt for service mailboxes
- ❗ Avoid auto-applying Do Not Forward encryption without informing user!

NIC26

PDF readers, encrypted PDFs & admin consent

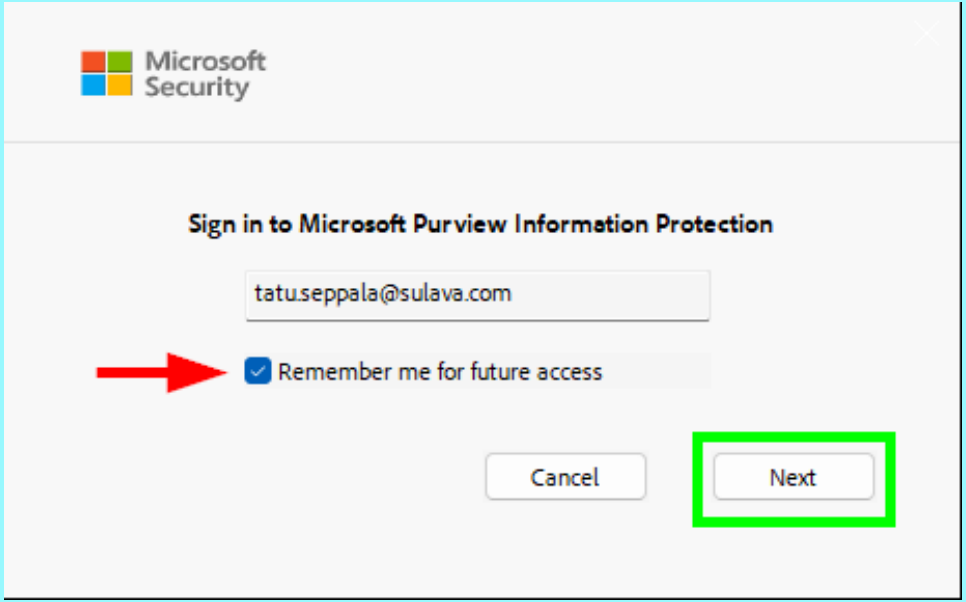


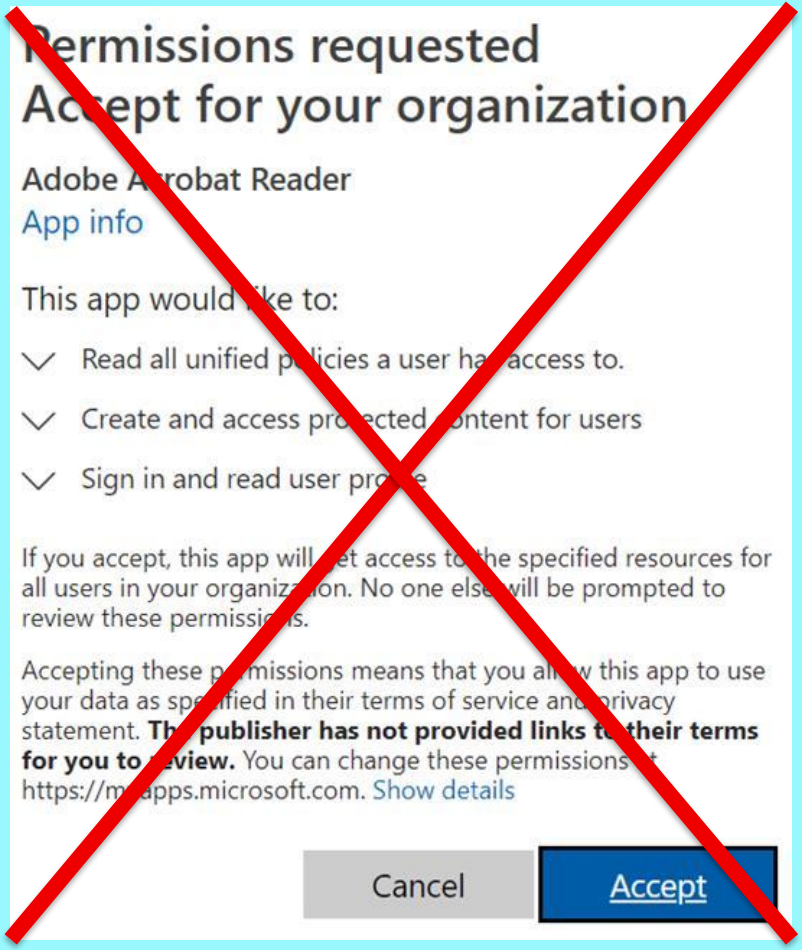
I saved a protected Word doc as a PDF. Now I’m getting this suspicious prompt from my PDF reader when I’m trying to open it!



NIC26

PDF readers, encrypted PDFs & admin consent

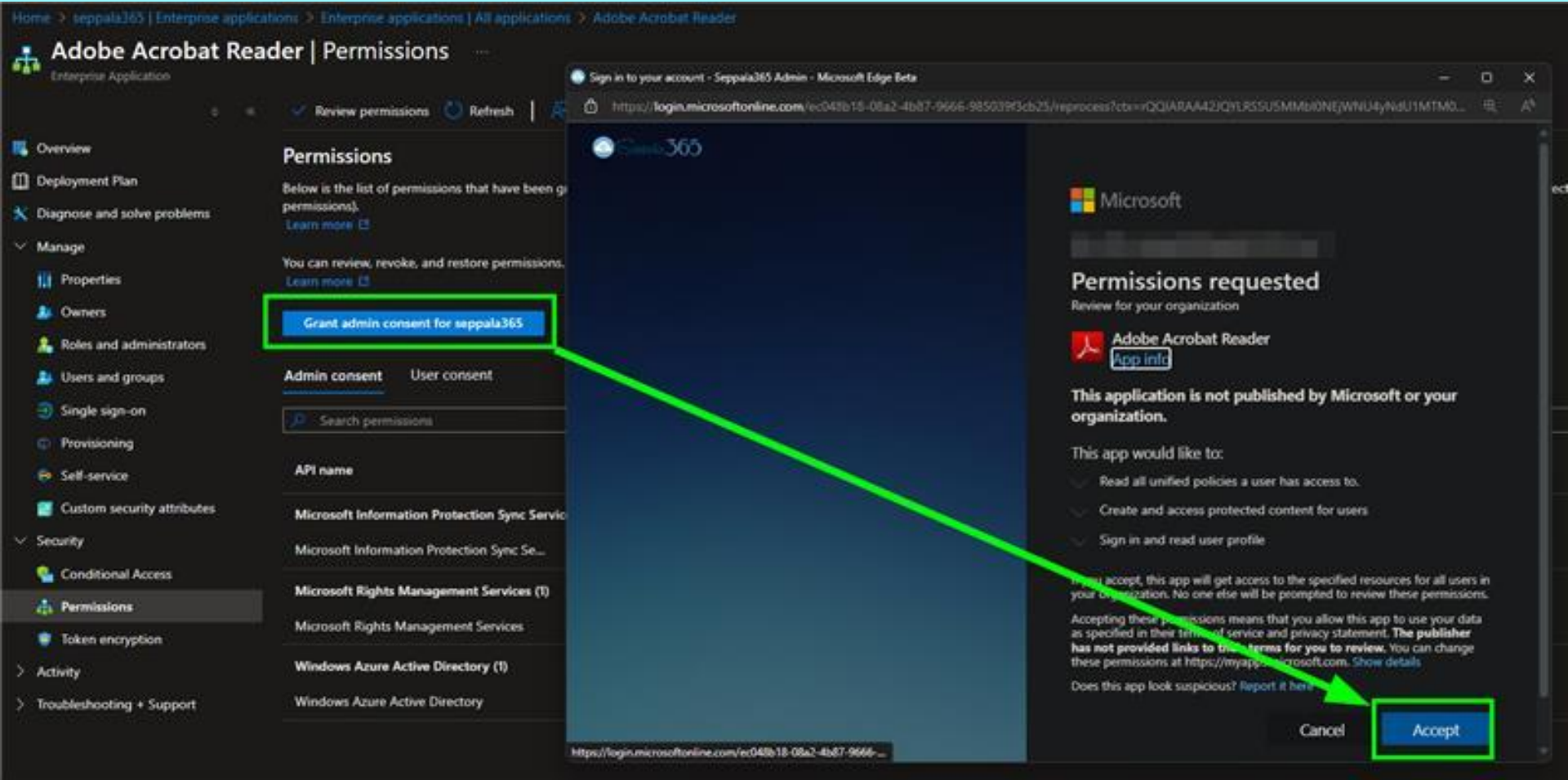


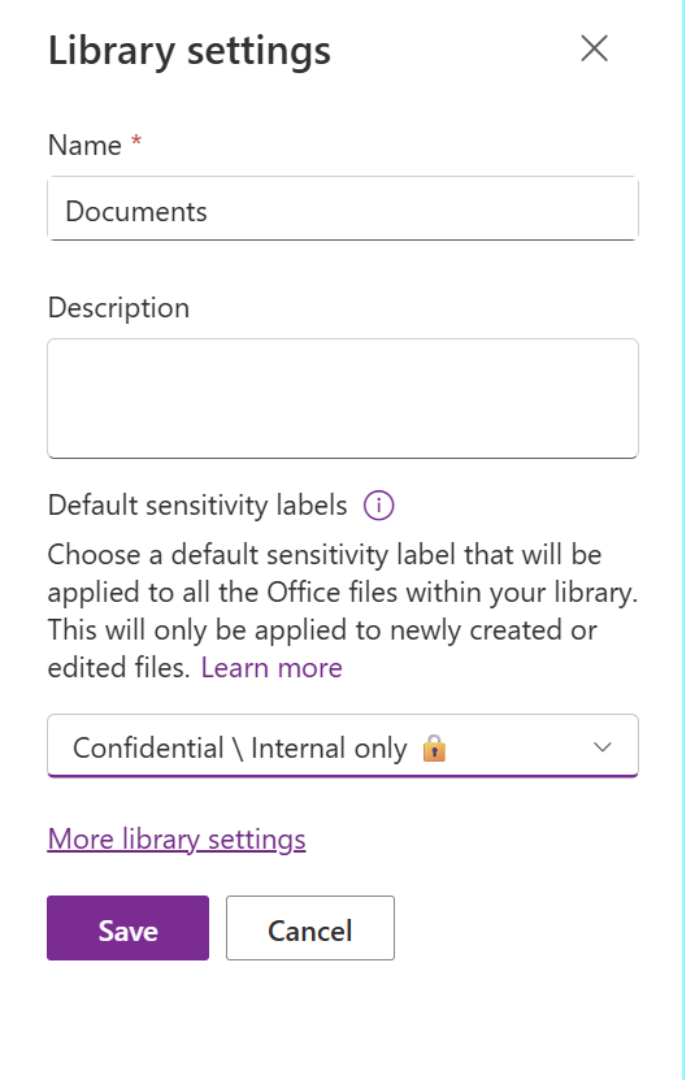


❗ Need to give admin consent to enterprise app before users can consent to these permissions!

NIGP6

PDF readers, encrypted PDFs & admin consent





Support users with automation

✅ Document library default labels

✅ Auto-labeling for pre-existing files per document library default label

✅ Recommended labels

✅ Sensitivity label inheritance from email attachments to email

Data Loss Prevention



DLP + Sensitivity labels = better together



Policy design



Rule naming conventions



Data-driven solution design



Teams DLP surprises



Understand your Sensitive Info Types



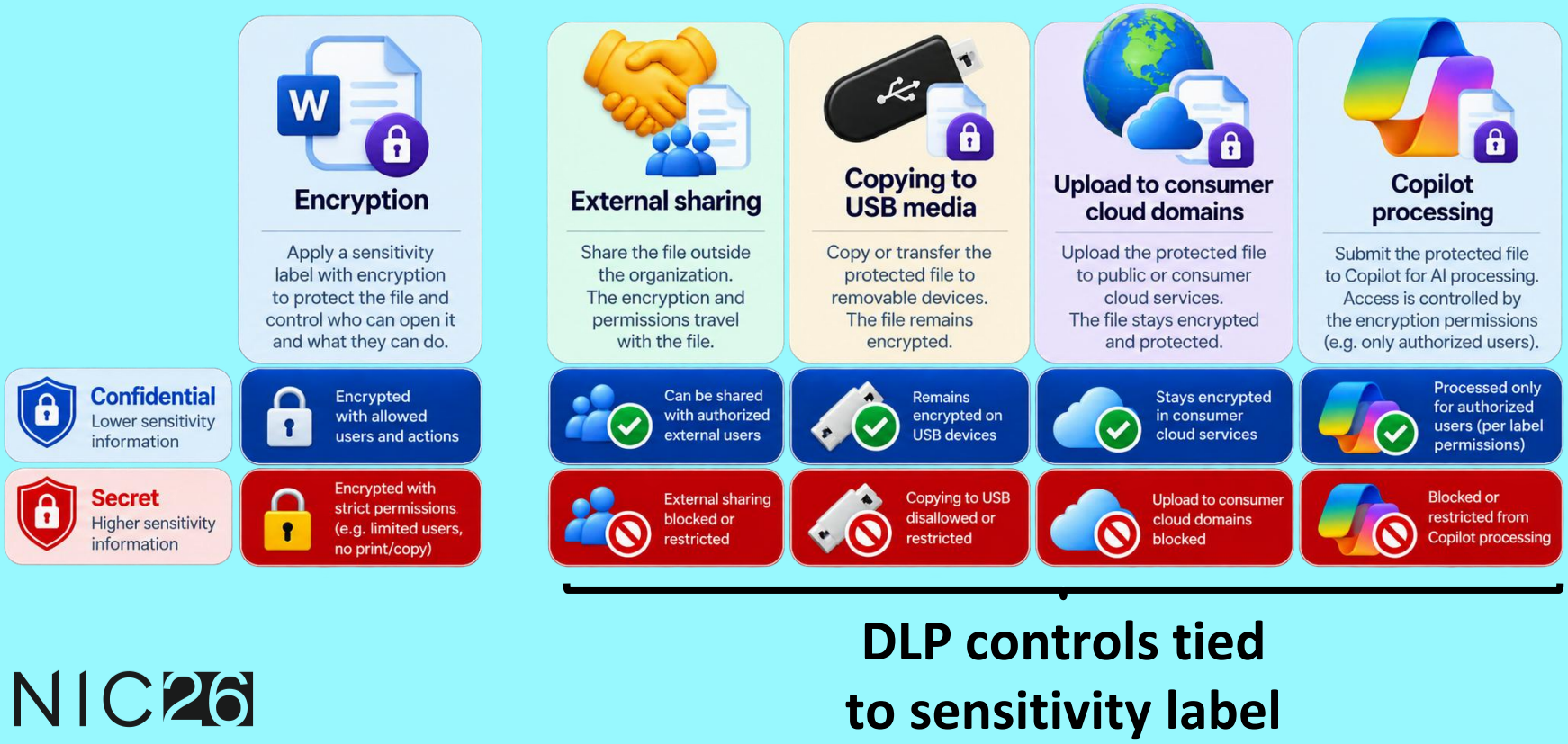
How to block the bad without breaking processes



DLP alerts are overrated

NIC26

DLP & Sensitivity labels - better together



NIC26

DLP policy design

Workload index#-Policy type-Workload

1000-Exchange-Prod	Production policy for all users
2000-SharePoint-Prod	Production policy for all users
3000-OneDrive-Prod	Production policy for all users
4100-Teams-Pilot	**Pilot** policy for limited users
5200-Endpoint-CLevel	**Limited** policy for high-prio users

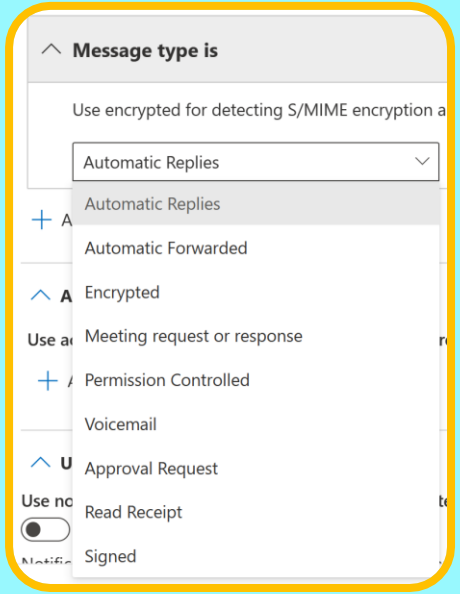
NIC26

DLP policy design

- 1000-Exchange-Prod
- 2000-SharePoint-Prod
- 3000-OneDrive-Prod
- 4100-Teams-Pilot
- 5200-Endpoint-CLevel

Benefits:

+ Can use **workload-specific conditions & actions**
+ Differentiated **policy tips & controls**
+ Granular **audit logging**



NIC26

DLP rule naming convention

Index# Workload Conditions Controls



1001-EXO-ConfidentialInternal-SharedExt-Block



2002-SPO-ConfidentialUnrestricted-SharedExt-Audit



3003-ODB-Secret-SharedExt-Block



4105-TMS-Credentials-Shared**Int**-PolicyTip



5201-EDP-Secret-BlockedActions

NIC26

Advanced hunting

Analyze audit logs w/ KQL to inform DLP solution design

New query* | eDLP / Files uploaded to cloud per domain*

Schema | Queries

Search

- printer
- eDLP / Files uploaded to cloud per application
- eDLP / Files uploaded to cloud per domain
- eDLP / Files uploaded to cloud per domain and user
- eDLP / Files uploaded to specific cloud domain per day per DLP rule
- MIP / Sensitivity labels details (applied & changed)

Run query | Set in query | Save | Share link | Create detect

Query

Query results are presented in your local time zone as per settings. Kusto filters, however, work in UTC. | Don't want to see it again

```
1  // KQL query written by Tatu Seppälä / tatu.seppala@sulava.com
2  CloudAppEvents
3  | where Timestamp >= ago(30d)
4  | where ActionType == "FileUploadedToCloud"
5  | project Timestamp, AccountId, RawEventData.FileType, RawEventData.ObjectId, RawEventData.TargetD
6  | extend ParentDomain = extract(@"[^.]+\.[^.]+$", 0, tostring(RawEventData_TargetDomain))
7  | summarize count() by tostring(ParentDomain), tostring(RawEventData_TargetDomain)
8  | sort by count_ desc
```

Getting started | Results | Query history

Export | 68 items | Search

Download to CSV

Copy to clipboard

ParentDomain	RawEventData_TargetDomain	count_
cloud.microsoft	m365.cloud.microsoft	44
microsoft.com	teams.microsoft.com	39
live.com	onedrive.live.com	38
azure.com	ai.azure.com	32

.CSV

New sensitive service domain group

Group name *

eDLP-UnauthorizedDomains

Sensitive service domain

Match type

URL

Sensitive service domain groups

chatgpt.com

*.chatgpt.com

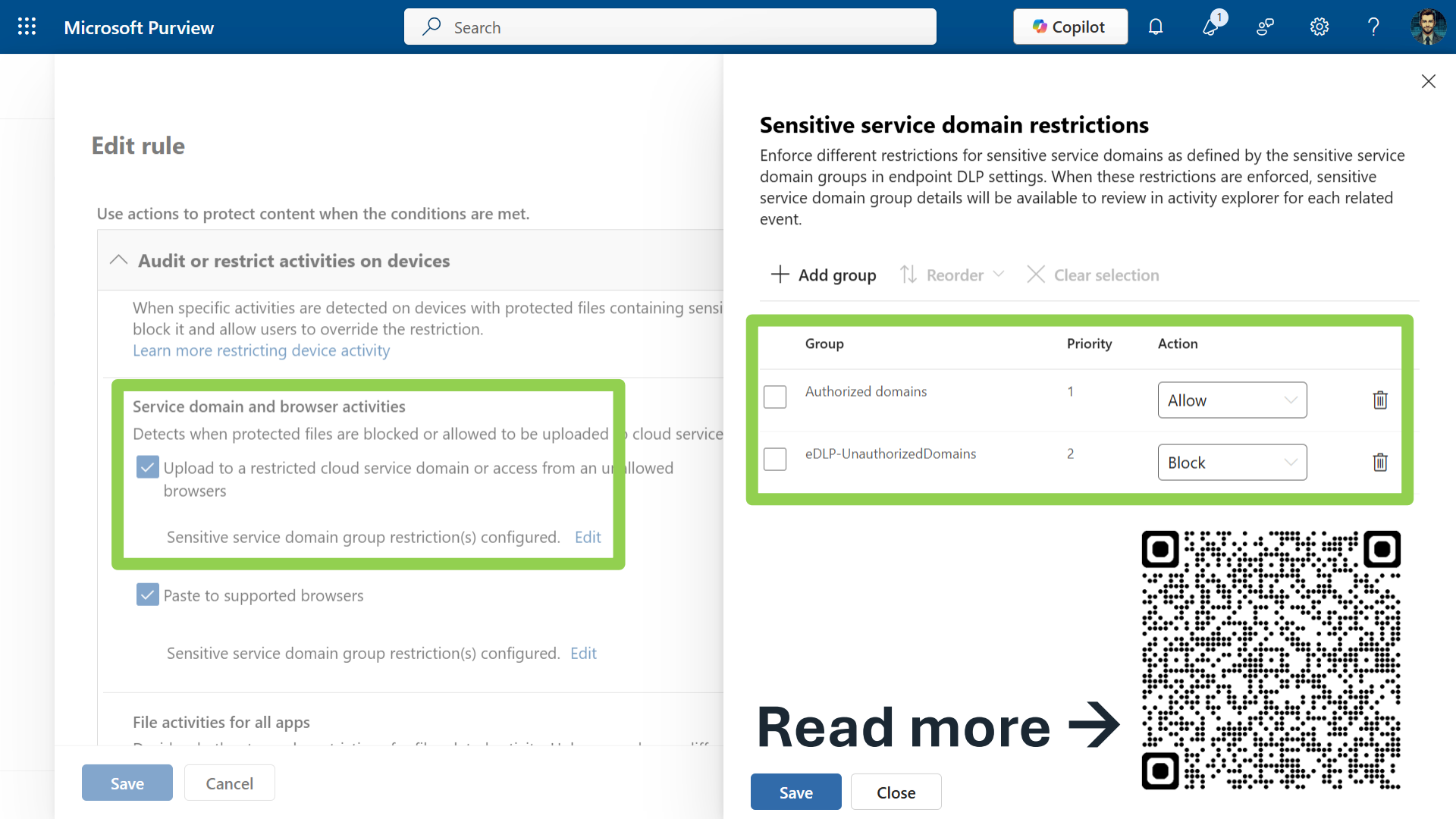
onedrive.live.com

mail.google.com

x.com

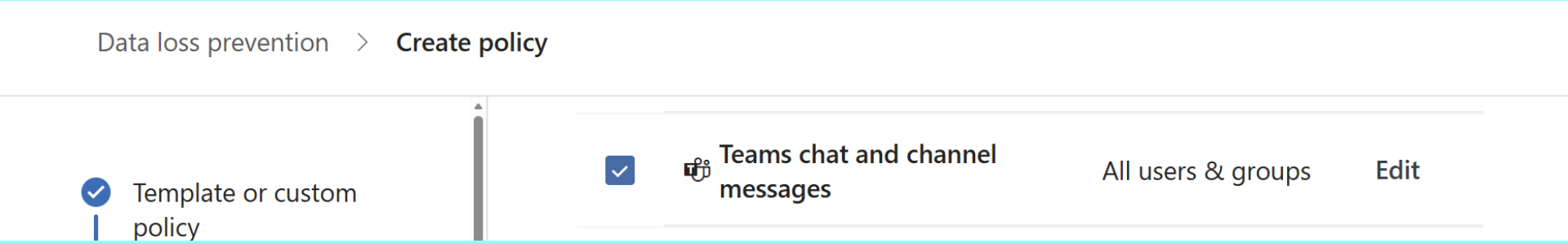
Save

Cancel


Microsoft Purview
Search
Copilot
Edit rule
Use actions to protect content when the conditions are met.
Audit or restrict activities on devices
When specific activities are detected on devices with protected files containing sensi
block it and allow users to override the restriction.
Learn more restricting device activity
Service domain and browser activities
Detects when protected files are blocked or allowed to be uploaded
cloud service
Upload to a restricted cloud service domain or access from an u
llowed
browsers
Sensitive service domain group restriction(s) configured. Edit
Paste to supported browsers
Sensitive service domain group restriction(s) configured. Edit
File activities for all apps
Save
Cancel
Sensitive service domain restrictions
Enforce different restrictions for sensitive service domains as defined by the sensitive service domain groups in endpoint DLP settings. When these restrictions are enforced, sensitive service domain group details will be available to review in activity explorer for each related event.
Add group
Reorder
Clear selection
Group
Priority
Action
Authorized domains
1
Allow
eDLP-UnauthorizedDomains
2
Block
Read more
Save
Close

Teams DLP surprises

- Says it applies to chats and channels..
- **Actually applies to files in Teams as well!**
  - Also, does not support sensitivity labels as a condition
- Be careful when blocking anything!



Understand SITs before you use them

```
PS C:\> $test.classificationresults

Name                           Value
----                           -----
Match
Ident
Confi
Count
Class
StreamName
ClassificationName             User Login Credentials
DetailedMatches
DetailedClassificationAttribu…
Matches                        {System.Collections.Hashtable}
Identity                       2de77d45-9d47-4ce2-990d-18e26b487194
ConfidenceLevel                75
Count                          1
ClassifierType                 None
StreamName
ClassificationName             User Login Credentials
DetailedMatches
DetailedClassificationAttribu…
Matches                        {System.Collections.Hashtable}
Identity                       2de77d45-9d47-4ce2-990d-18e26b487194
ConfidenceLevel                85
Count                          1
ClassifierType                 None
StreamName
ClassificationName             User Login Credentials
DetailedMatches
DetailedClassificationAttribu…
```

confidence match

Medium confidence match

High confidence match

Definition

A DLP policy has high confidence that it's detected this type of sensitive information if, within a proximity of 300 characters:

- The function `Func_credit_card` finds content that matches the pattern.
- One of the following conditions is true:
  - A keyword from `Keyword_cc_verification` is found.
  - A keyword from `Keyword_cc_name` is found.
  - The function `Func_expiration_date` finds a date in the right date format.
- The checksum passes.

A DLP policy has low confidence that it's detected this type of sensitive information if, within a proximity of 300 characters:

- The function `Func_credit_card` finds content that matches the pattern.
- The checksum passes.

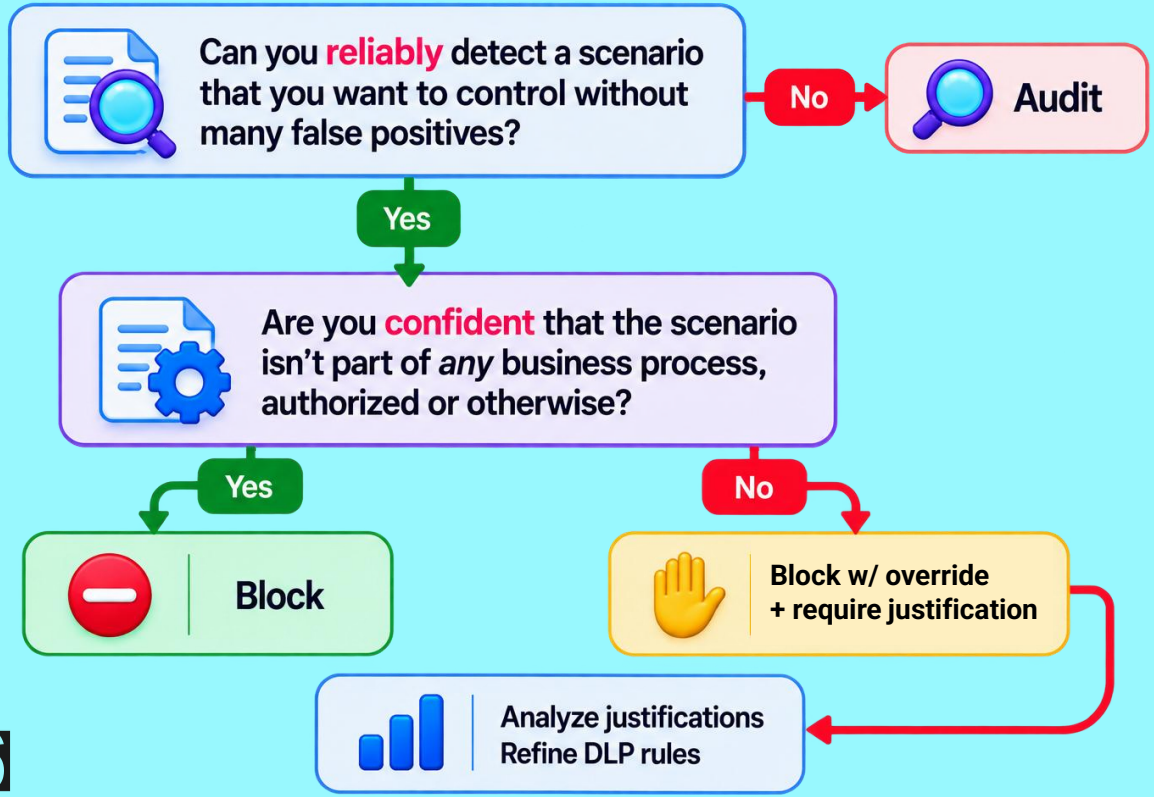
XML Copy

```xml
<!-- Credit Card Number -->
<Entity id="50842eb7-edc8-4019-85dd-5a5c1f2bb085" patternsProximity="300" recommendedConfi
  <Pattern confidenceLevel="85">
        <IdMatch idRef="Func_credit_card" />
        <Any minMatches="1">
          <Match idRef="Keyword_cc_verification" />
          <Match idRef="Keyword_cc_name" />
          <Match idRef="Func_expiration_date" />
        </Any>
  </Pattern>
  <Pattern confidenceLevel="65">
        <IdMatch idRef="Func_credit_card" />
  </Pattern>
</Entity>
```

Understand SITs before you use them

- Confidence levels matter more than the attention people give them
- The quality of SITs varies **wildly!**
- Unbundled SITs (for ex. **IPv4** instead of **IP Address**) often lead to better outcomes
  - More accurate criteria
  - Easier to exclude problematic ones after rollout

How to ⛔ Block the bad without breaking processes



NIC26

DLP alerts are overrated



We don’t need to know 15 times per day that Jake from Operations printed a confidential document. It’s clogging up our alert feed!

Incident reports

Use this severity level in admin alerts and reports: Low

Send an alert to admins when a rule match occurs.

On

Send email alerts to these people (optional)

Add or remove users

Send alert every time an activity matches the rule

NIC26

DLP alerts are overrated



- Unless you are **absolutely** sure your SOC team needs alerts from people triggering a particular DLP rule, don’t use them!
- You can easily clog your alert feed with low quality, non-actionable alerts
- In my opinion, DLP is <u>not</u> an attacker prevention tool

NIC26

What about 3P EDR vendors?

- You can still gather Purview device audit logs if you use for ex. **CrowdStrike Falcon** as an EDR.
- Endpoint DLP enforcement might be hit and miss at times.. but is supported.
- Ensure **mutual exclusions** are in place between MDE and 3P EDR components according to MS & vendor guidance.

Running the implementation

Better living through ring-based deployment



- Expanding the audience of a poorly-tested data security solution = **best way to get a lot of new friends fast**
- Lots of things break at once, everyone yells and you get overwhelmed
- Next time will be more difficult to “sell” to execs due to bad experience last time around
- Instead, plan for compatibility issues and encounter them gradually!

🧪 **Ring 1 -** Hands-on design



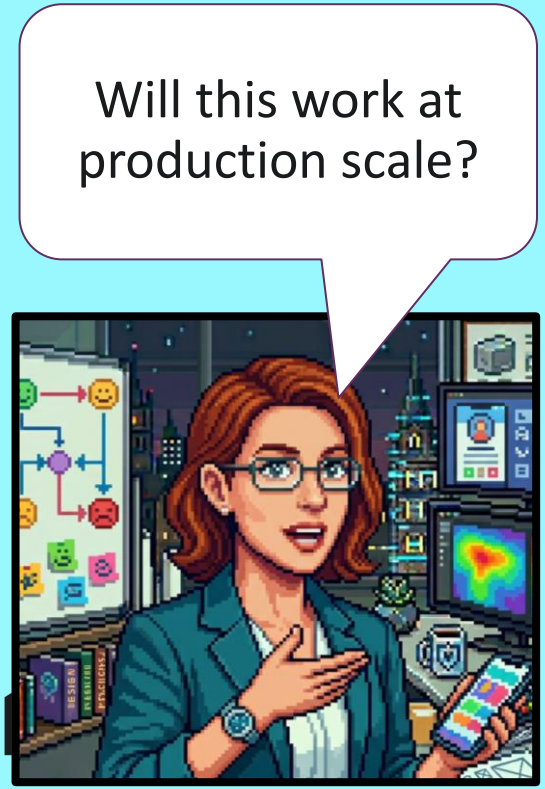
- Easy to get sidetracked into endless PowerPoint Olympics w/ folks who have never used sensitivity labels & DLP
- Incorporate technical pilot from the start. The project team tests design decisions in practice **ASAP**
- Keeps decisions grounded in reality & curbs extra idealism around what people are willing to put up with

Ring 2 - Controlled crisis



- Processes breaking at scale will sink your solution and business sentiment fast
- Bring in hand-picked **LoB app responsibles** as well as **key users** from departments / roles routinely handling sensitive data
- Your goal is to **run into critical issues early** w/ folks who might be impacted the most
- Document issues, build scalable workarounds and prepare end user guidance for special cases

🚗 **Ring 3 -** Stress test / full pilot



- The smoke test for your production rollout
- No cherry-picking! Either..
  - Randomized selection of 10-15% of entire org
  - Entire departments at a time
- Comms, guidance & support executed like they will be in production

N

Showtime means hypercare



- Production rollout in **multiple batches** to avoid overwhelm if issues arise
- **Monitor label usage** for large-scale misuse and indicators of usability issues (mass encryption removal etc.)
- **Track service desk tickets** and flag systemic issues early & fast
- **Early sentiment is everything** - do not break business processes at scale!

💖 Thank you!

- Q&A
- Please rate the session on the app to see more content you like next year!

NIC26